



APPLIED TECHNOLOGY ACADEMY • TWO-DAY PRACTICUM

Threat Modeling and Secure Code Review

Model the system, investigate the implementation, verify the evidence, and brief a defensible recommendation.

TWO DAYS • ONE CONTINUOUS FRX REVIEW

Each day produces the evidence the next decision needs

DAY 1 • THREAT MODELING

Orient the existing system; model assets, flows, stores, and boundaries; develop causal threats; decide risk responses and verification; reconcile the model through peer review.

Formal labs 1–4 • one continuous FRX model and review record.

DAY 2 • SECURE CODE REVIEW

Plan and navigate the review; collect manual evidence; apply governed criteria; validate tool signals; verify proposed changes; brief a named decision owner.

Formal labs 1–6 plus two guided practices • the same FRX record carried into the code review.

Requirements, observations, findings, checklist status, remediation proof, risk, recommendation, and authorized disposition remain linked—but never interchangeable.



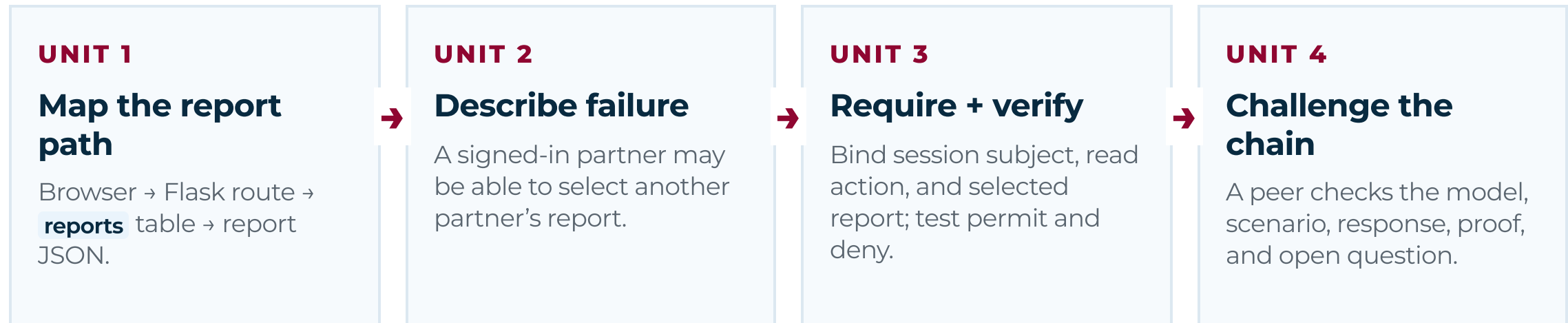
THREAT MODELING AND SECURE CODE REVIEW

Day 1 • Threat Modeling Practicum

Model the system, develop defensible scenarios, decide responses, and challenge the result.

DAY 1 • ONE FRX REVIEW, FOUR DECISIONS

Every unit makes the same FRX record more useful



The diagram, scenario, risk response, and review comment are different views of one evidence chain.



DAY 1 • UNIT 1

System and asset modeling

Turn a real workflow into a security model another analyst can investigate.

Four questions turn FRX evidence into review work

01**What exists?**

Browser client, Flask routes, SQLite tables, file intake, audit log, analytics provider.

**02****What can go wrong?**

A caller changes a report ID, query text, filename, or provider resource.

**03****What should change?**

State the required authorization, validation, preservation, or failure behavior.

**04****How will we know?**

Identify source evidence plus a normal case, denial case, and remaining uncertainty.

The framework is useful only when every answer names a real FRX component, datum, decision, or observation.

A USEFUL SYSTEM MODEL

The FRX model is larger than any one diagram

FACTS AND DECISIONS

Scope: the supplied vulnerable portal and local analytics fixture.

Assets: report rows, credentials, session state, uploaded bytes, audit evidence, service availability.

Rules: partners read owned reports; analysts read assigned reports.

VIEWS AND UNCERTAINTY

Views: context, components, data relationships, message sequence, and data flow.

Evidence: routes, schema, browser behavior, and supplied architecture.

Questions: where is report entitlement enforced, and what evidence would prove it?

A diagram communicates selected relationships. The model also includes scope, assets, rules,^{7/191} evidence, assumptions, and unresolved questions.

Five marks describe the report-read path

E • EXTERNAL ENTITY

Browser caller supplies a session cookie and report ID.

D • DATA STORE

SQLite reports persists owner, assignment, classification, and summary fields.

P • PROCESS

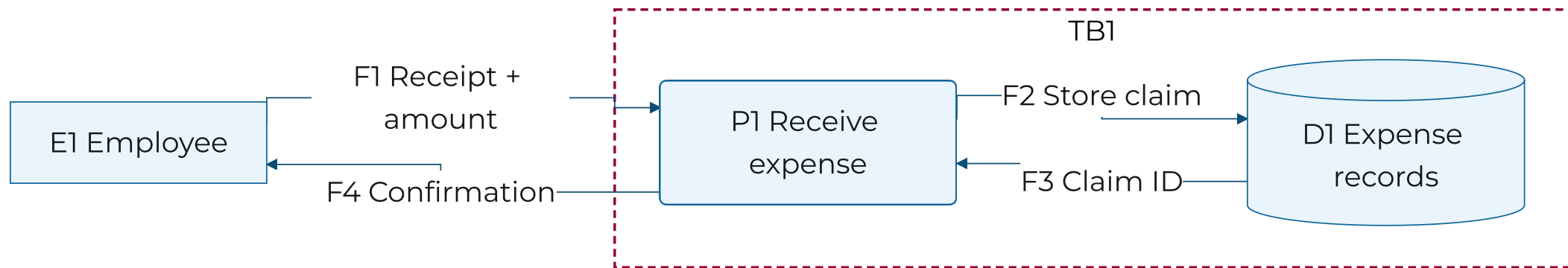
Read report receives the request and releases a response.

F • DIRECTED FLOW

Report query → and **report row** ← name data and direction.

TB • Trust boundary: TB1 marks where caller-controlled input crosses into portal enforcement authority.

Read the generic DFD as a sentence



The employee supplies F1. P1 stores the claim through F2, receives F3, and returns F4. TB1 explains where application authority begins.

TB1 marks a specific change in authority

BOUNDARY STATEMENT

When the browser sends a session cookie and report ID to **Read report**, control changes from caller-supplied input to portal enforcement.

That statement creates review questions

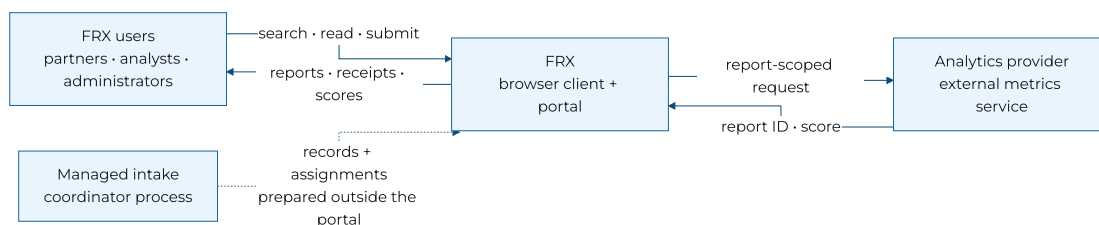
- Which identity does the cookie establish?
- Which report does the path select?
- Where are owner or assignment rules enforced?
- What returns when the caller is not entitled?

A network hop, process box, or file edge is not automatically a trust boundary. Name the change in control, authority, or responsibility.

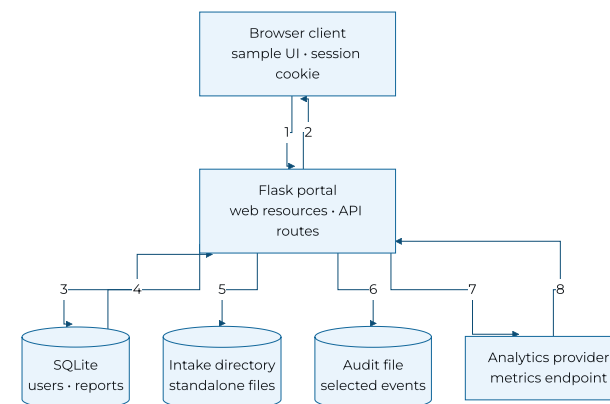
ONE MODEL • COORDINATED VIEWS

One FRX model needs several diagrams

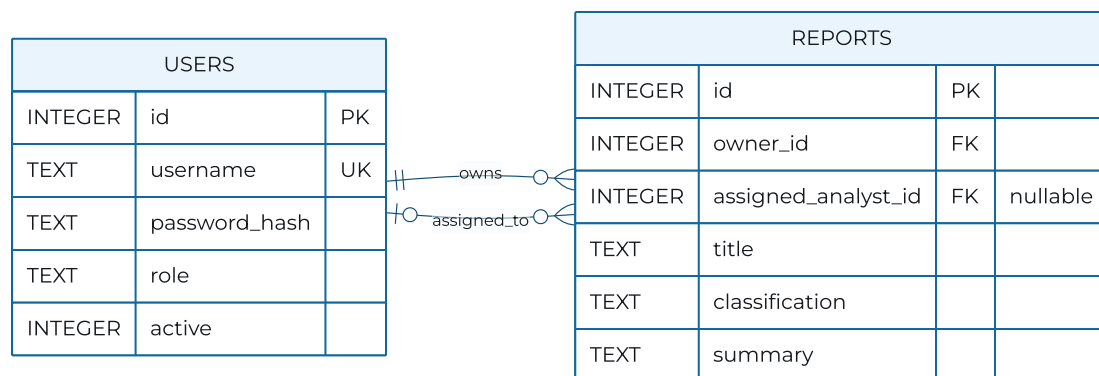
1 • CONTEXT



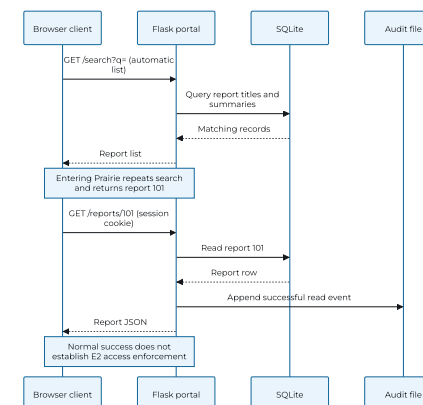
2 • COMPONENTS



3 • DATA RELATIONSHIPS



4 • MESSAGE SEQUENCE



Start with report 101—not a generic “data system”

NORMAL REPORT PATH

partner.alex signs in, searches for **Prairie**, opens report **101**, and receives its title, classification, and observation summary.

ADJACENT PATHS

The browser can request analytics score **7**. Document intake stores a standalone file receipt; it does not attach the file to report 101.

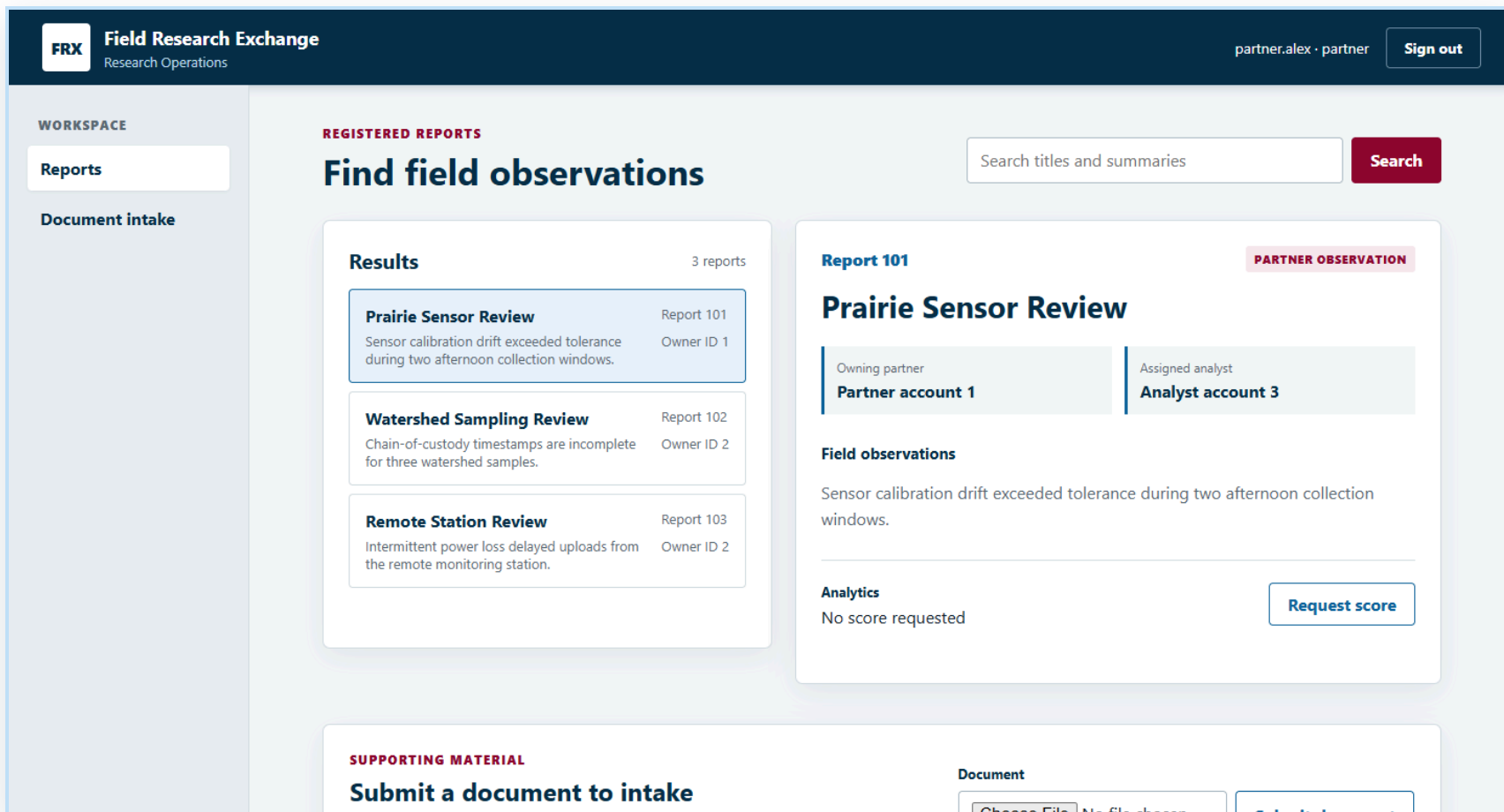
The concrete workflow tells us which identities, records, inputs, outputs, stores, and effects the model must represent.

The schema names relationships; the policy decides access

Subject	Object	Intended result	Evidence still needed
partner.alex	Report 101, owner_id=1	Permit read	Route-level owner check
partner.alex	Report 102, owner_id=2	Deny protected fields	Negative behavior and source branch
analyst.riley	Report 101, assigned_analyst_id=3	Permit assigned read	Assignment enforcement

FRX has no separate authentication service in the supplied build. Session identity and report authorization are portal responsibilities.

One screen exposes three different review surfaces



The screenshot displays the FRX (Field Research Exchange) browser client interface. The top navigation bar includes the FRX logo, the text "Field Research Exchange" and "Research Operations", the user "partner.alex · partner", and a "Sign out" button. The left sidebar shows a "WORKSPACE" menu with "Reports" and "Document intake". The main content area is titled "REGISTERED REPORTS" and "Find field observations". It features a search bar with the placeholder "Search titles and summaries" and a "Search" button. Below the search bar, there are three report cards under the heading "Results" (3 reports). The first card is "Prairie Sensor Review" (Report 101, Owner ID 1) with the summary "Sensor calibration drift exceeded tolerance during two afternoon collection windows." The second card is "Watershed Sampling Review" (Report 102, Owner ID 2) with the summary "Chain-of-custody timestamps are incomplete for three watershed samples." The third card is "Remote Station Review" (Report 103, Owner ID 2) with the summary "Intermittent power loss delayed uploads from the remote monitoring station." To the right of these cards is a detailed view for "Report 101", labeled "PARTNER OBSERVATION". This view shows the "Owning partner" as "Partner account 1" and the "Assigned analyst" as "Analyst account 3". It includes a section for "Field observations" with the same summary as the first report card. Below this is an "Analytics" section stating "No score requested" and a "Request score" button. At the bottom of the interface, there is a "SUPPORTING MATERIAL" section titled "Submit a document to intake" with a "Document" label and a "Choose File" button.

1 · SEARCH

Titles, summaries, owner IDs.

2 · READ

Selected report content.

3 · SCORE

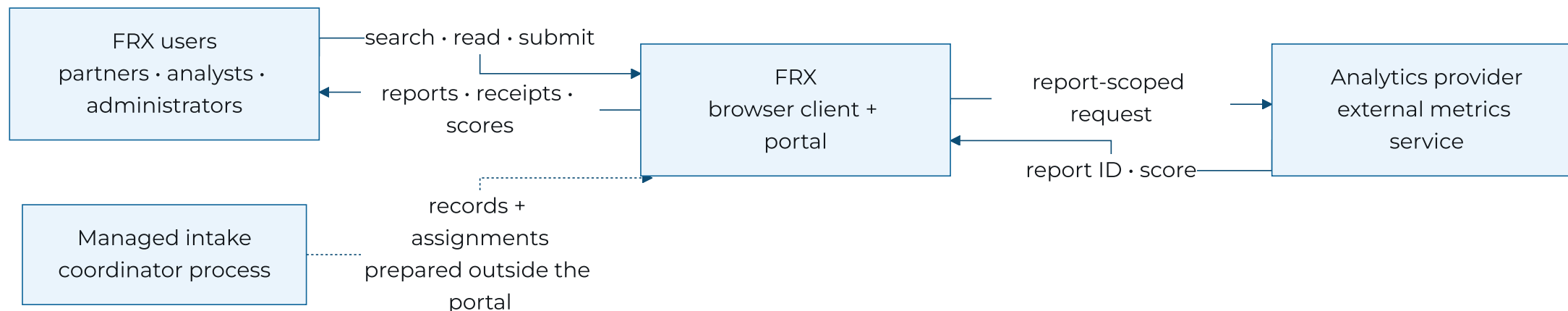
Provider result for a report.

4 · INTAKE

Standalone file receipt.
14 / 191

VIEW 1 • SYSTEM CONTEXT

The context view fixes scope before security questions

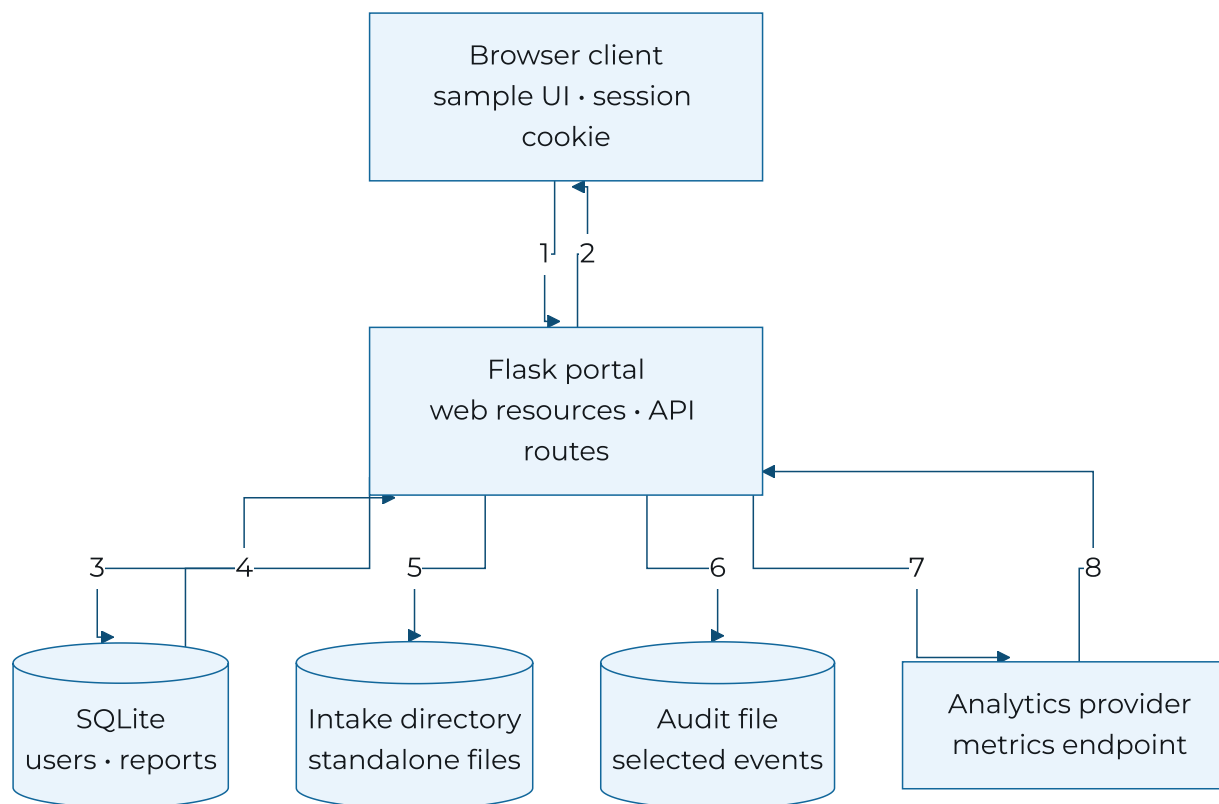


Inside this review: browser/portal exchanges and the provider request/response.

Outside this implementation: the managed process that prepares records and assignments.

VIEW 2 • IMPLEMENTATION COMPONENTS

The component view exposes exact stores and side effects



SQLite: users + reports **Directory:** uploaded bytes **Audit:** selected events **Provider:** report score

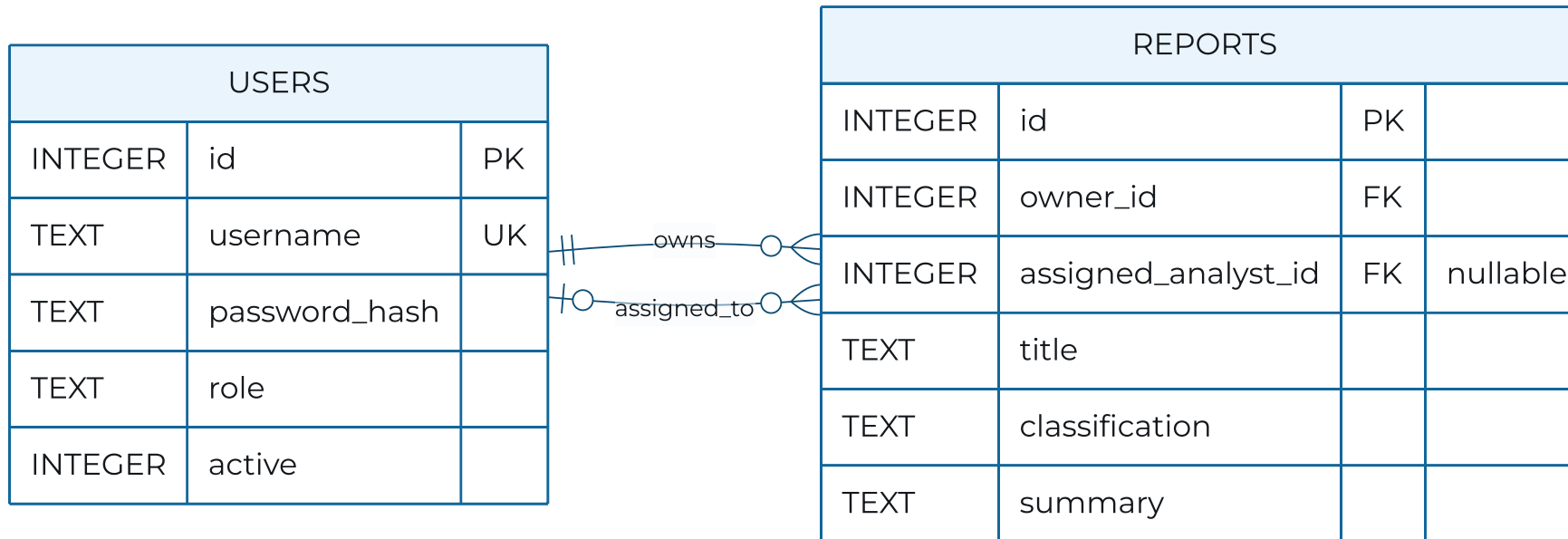
Every FRX route must land in a model view

Interface	Input	Store or dependency	Observable effect
POST /login	username + password	users + audit file	session cookie or denial
GET /search , /reports/{id}	query or report ID + session	reports + audit on detail	report list or report JSON
POST /documents	filename + bytes + session	intake directory + audit	storage receipt
/analytics/*	URL or encoded payload + session	provider or in-process inspection	score JSON or format metadata

Also account for /welcome , /errors/demo , static content, logout, and health—even when the sample client does not expose a button.

VIEW 3 • RELATIONAL DATA

The schema records ownership; the route must enforce it



Concrete assets: `reports.summary`, `classification`, `owner_id`, `assigned_analyst_id`, and `users.password_hash`.

Security question: where does the route compare the authenticated subject with the selected report's owner or assigned analyst?

VIEW 4 • SIGN-IN SEQUENCE

The sequence view shows where credentials become a session

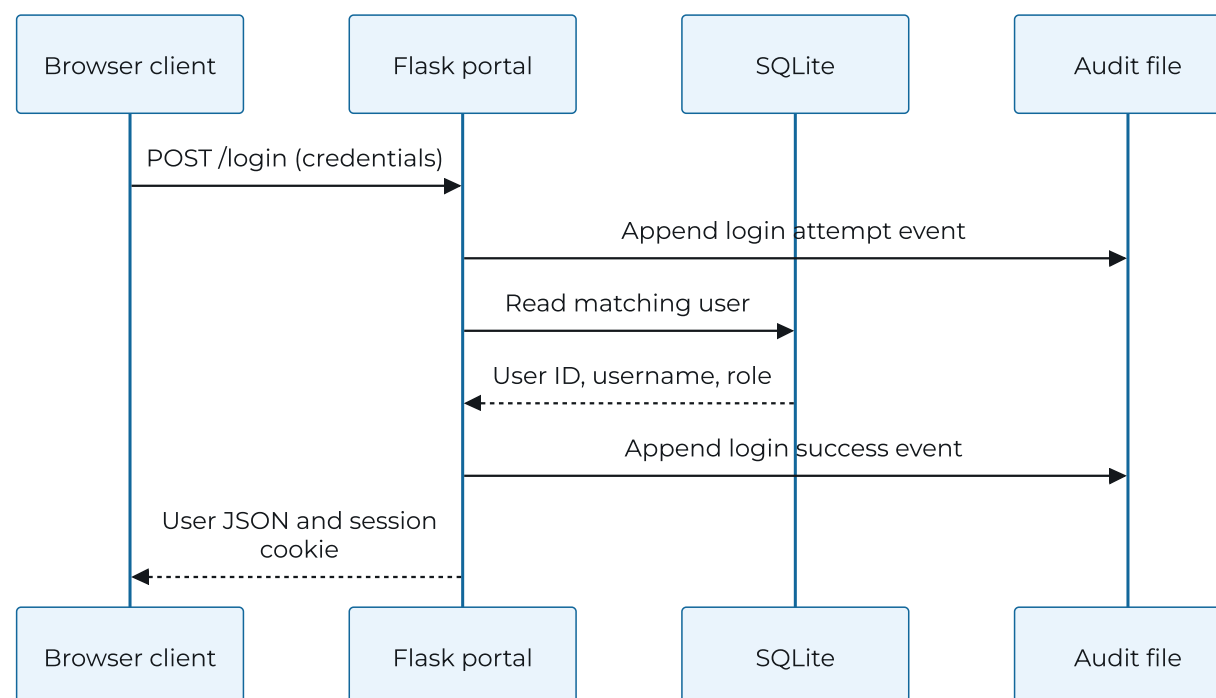
TRACK FOUR EFFECTS

Credentials cross from browser to portal.

The portal queries **users**.

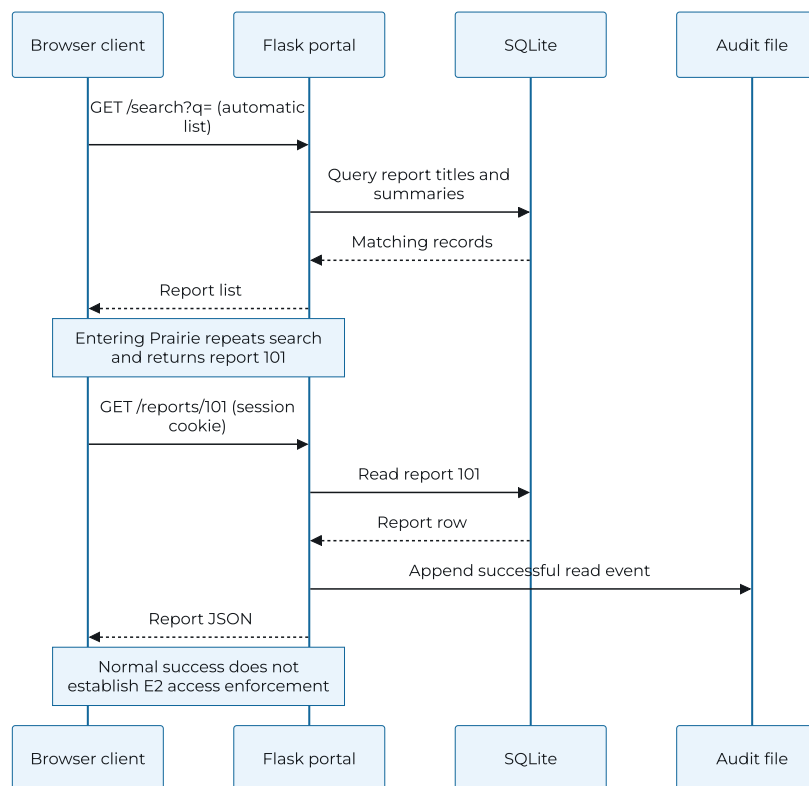
Login events append to the audit file.

A session cookie returns to the browser.



VIEW 4 • REPORT SEQUENCE

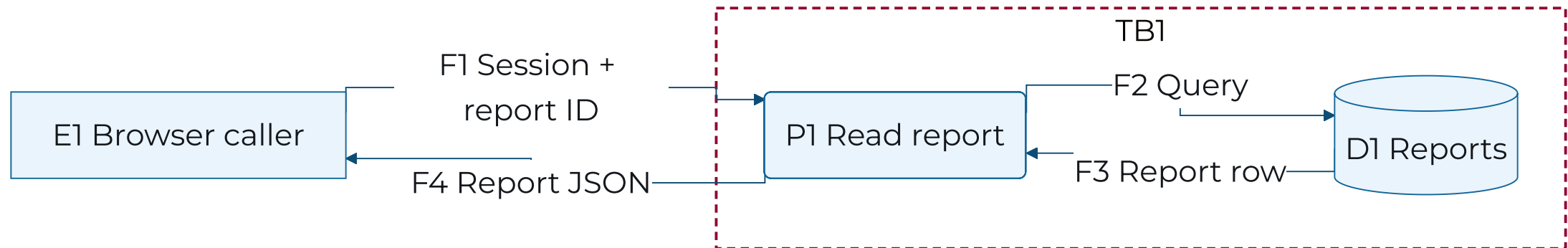
Search and report release are separate decisions



A successful read proves that one arranged path returned report 101. It does not prove that report 102 would be denied to the same caller.

VIEW 5 • REPORT-READ DFD

Four named flows make the trust decision testable



F1–F3: session + report ID, database query, and returned row establish the selection path.

F4: report JSON is the disclosure effect; TB1 identifies where caller intent must become authorized service action.

A session check is not a report-entitlement check

AUTHENTICATION EVIDENCE

`_authenticated()` asks whether `user_id` exists in the session.

That can establish a signed-in subject such as **partner.alex**.

AUTHORIZATION EVIDENCE NEEDED

The selected report has `owner_id` and optional `assigned_analyst_id`.

The review must locate the decision that binds that subject to **report 102** before returning fields.

Do not invent an external identity service: in this supplied build, Flask session handling and route logic carry the decision.

“Asset” means the exact thing whose loss would matter

Asset	Concrete location or form	Protection need	Consequence
Report data	<code>reports.summary</code> , JSON response, browser memory	Confidentiality + integrity	Partner observations exposed or misattributed
Identity + secrets	<code>password_hash</code> , session cookie, signing key	Confidentiality + authenticity	Unauthorized session or false attribution
Evidence	<code>audit.log</code> , file receipt, analytics response	Integrity + availability	Review cannot reconstruct who did what
Service + source	Flask portal, SQLite file, <code>vulnerable.py</code> , runtime configuration	Availability + integrity	Required research work stops or behavior changes

Seven steps turn FRX evidence into a reviewable model

STEPS 1–4 • ESTABLISH WHAT EXISTS

1. Observe report 101 and adjacent workflows.
2. Bound the supplied baseline and exclusions.
3. Name assets with exact locations and consequences.
4. Extend the report-read DFD across remaining routes.

STEPS 5–7 • MAKE IT TESTABLE

5. Label every element and directional flow.
6. Justify boundaries and assign evidence questions.
7. Reconcile diagrams, asset records, source facts, and unknowns.

The result is not “a diagram.” It is a scoped, evidence-linked model communicated through coordinated views.

Build a model another analyst can investigate

OPEN

Lab 1 student guide, FRX review document, system evidence packet, and supplied diagrams.

DO

Complete Steps 1–7.
Extend the report-read fragment across the remaining review surface.

PRODUCE

SCOPE-1, assets, DFD, flow key, boundary reasons, and evidence-owned questions.

Check: 1A after Step 3 • 1B after Step 7

Can another analyst trace it without your narration?

Trace

Point to a request, its returned data, and the store or service involved.

Boundary

Explain what changes in authority or responsibility across one TB.

Uncertainty

Name one unverified control, the evidence owner, and the decision affected.

Correction

Show one omission you fixed—or why the supplied evidence supports retaining the model.

Keep the IDs. Unit 2 will apply STRIDE to specific elements and flows, beginning with F1 and Q1.

From DFD to defensible threat scenarios

Trace a plausible failure before naming a vulnerability.

One report request can support four different statements

Threat event

A signed-in partner requests report 102, which belongs to another partner.

Weakness hypothesis

The report route may check session presence without checking `owner_id` or assignment.

Vulnerability finding

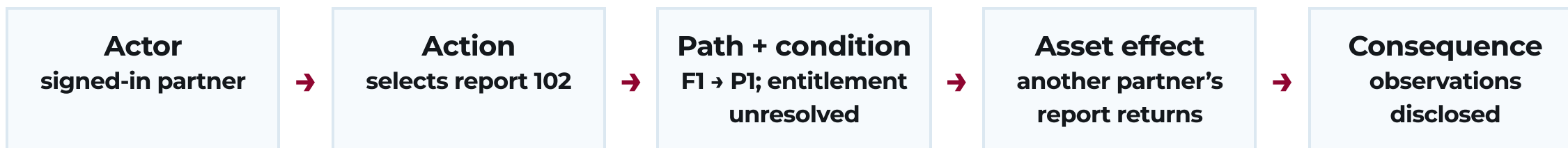
Day 2 source and runtime evidence confirms the missing object-level decision in the reviewed baseline.

Consequence

Watershed observations and attribution are disclosed to an unauthorized partner.

Day 1 may retain the threat and the evidence question. It must not promote the hypothesis into a confirmed finding.

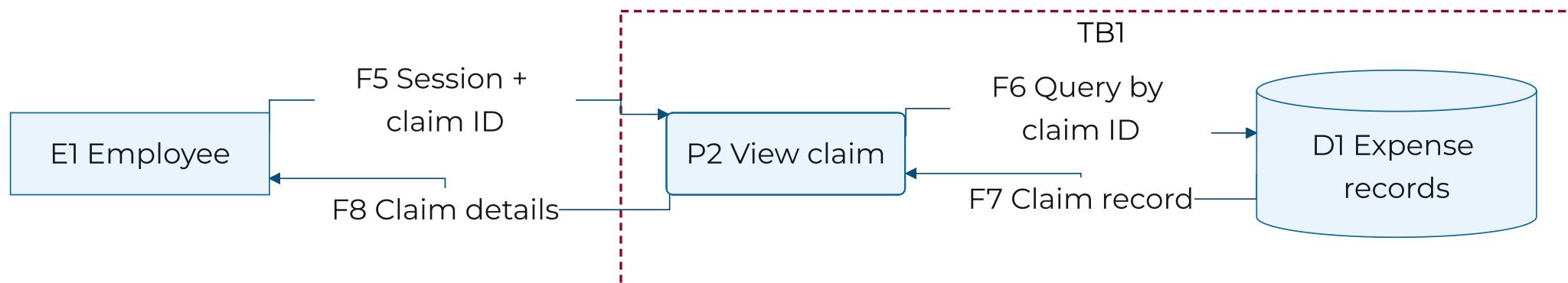
Write the FRX scenario as a causal chain



“Broken access control in reports” is a category label. The chain above tells another analyst what to investigate and what harmful result matters.

DIAGRAM-DRIVEN DISCOVERY • NEUTRAL EXAMPLE

The diagram identifies surfaces; evidence determines the scenario



F5: Which claim key can the employee influence?

P2: Where is employee-to-claim entitlement decided?

F8: Which protected fields could return?

The boxes and arrows create investigation prompts—not vulnerability findings.

Every FRX element should produce a specific question

Element	Concrete FRX question	Evidence that could answer it
E1 browser caller	Which session identity originates report 102?	Login/session source and observed cookie
P1 read report	Where does subject-to-report authorization occur?	Route branches and helper calls
D1 reports	Which owner and assignment fields exist?	Schema and fixture row
F4 report JSON	Which fields leave the portal on permit or denial?	Response construction and runtime body
TB1	Which trusted decision mediates caller-controlled selection?	Policy owner plus enforcement point

TB1 is where report selection must become authorized action

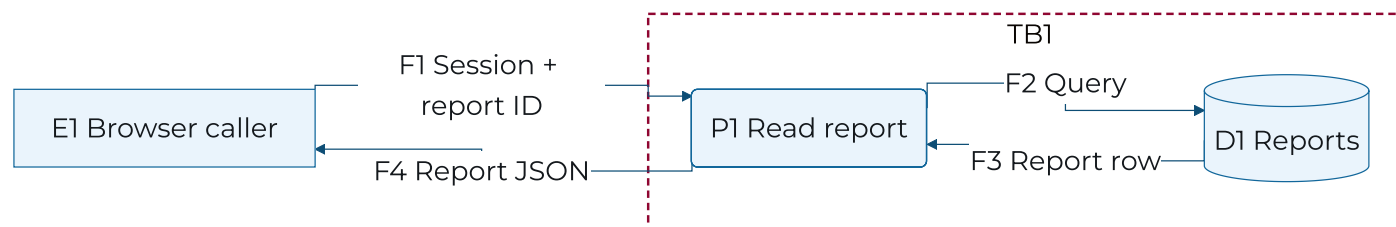
SCENARIO SEED

Actor: signed-in partner

Input: report ID 102

Decision: owner or assignment

Effect: protected report JSON



The model supports the question. Day 2 must establish whether the reviewed route enforces the decision.

Search text reaches a database interpreter

MODELED PATH

Browser sends **GET /search?q=Prairie** .

The Flask search process reads
SQLite report titles and summaries.

A report list and query
representation return to the caller.

QUESTION—NOT FINDING

Does caller-controlled **q** remain
data when the SQL statement is
constructed?

Confirm with: source construction,
database call, error behavior, and
parameterization evidence.

**SQLite and caller input create a credible investigation path. Only
implementation evidence can establish CWE-89.**

Report 102 makes the authorization question concrete



A numeric ID is not the vulnerability. The question is whether the trusted service authorizes the selected object.

SAME PATH • DIFFERENT MECHANISMS

SQL injection and IDOR ask different questions

SQL INJECTION

Input changes command grammar.

Key evidence: query construction and separation of data from SQL.

Candidate: A05 / CWE-89.

OBJECT AUTHORIZATION / IDOR

Input remains a valid object key.

Key evidence: subject-to-object entitlement on every access path.

Candidate: A01 / CWE-639.

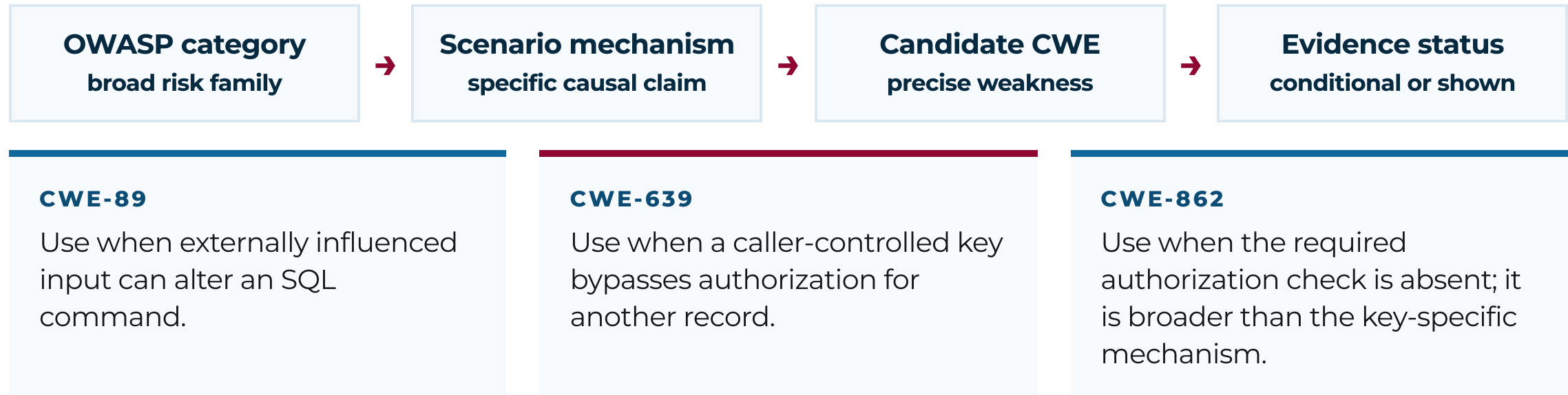
Both can disclose records. The shared consequence does not make the mechanisms interchangeable.

STRIDE changes the question you ask of each FRX surface

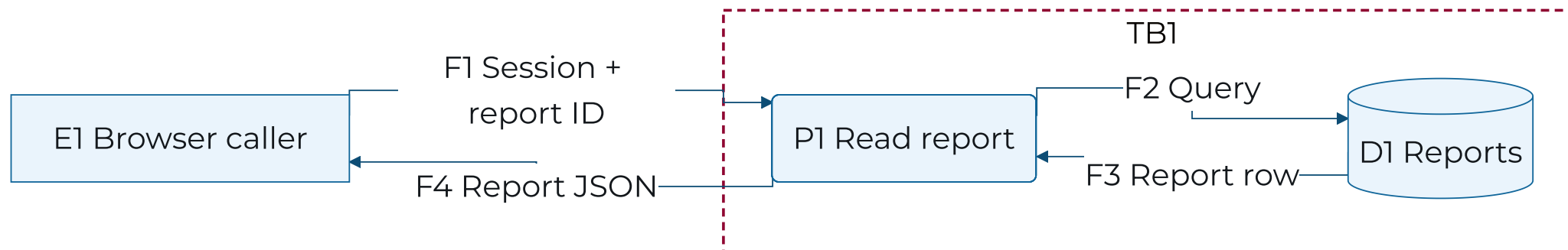
Prompt	FRX surface	Concrete question
Spoofing	Login + session cookie	Can another actor obtain or forge the identity the portal trusts?
Tampering	Search text + uploaded filename	Can input change query meaning or replace acknowledged bytes?
Repudiation	Audit file	Do events identify the action without exposing secrets?
Information disclosure	Report JSON + error response	Can protected fields or internal details reach the wrong caller?
DoS / elevation	Upload, provider, report selection	Can work be exhausted or portal authority exceed caller entitlement?

CWE PRECISION

Choose the narrowest mechanism your evidence supports



The model supplies the path; the packet supplies the rule and the gap



REQUIREMENT • E2

Partners may read reports they own; analysts may read assigned reports.

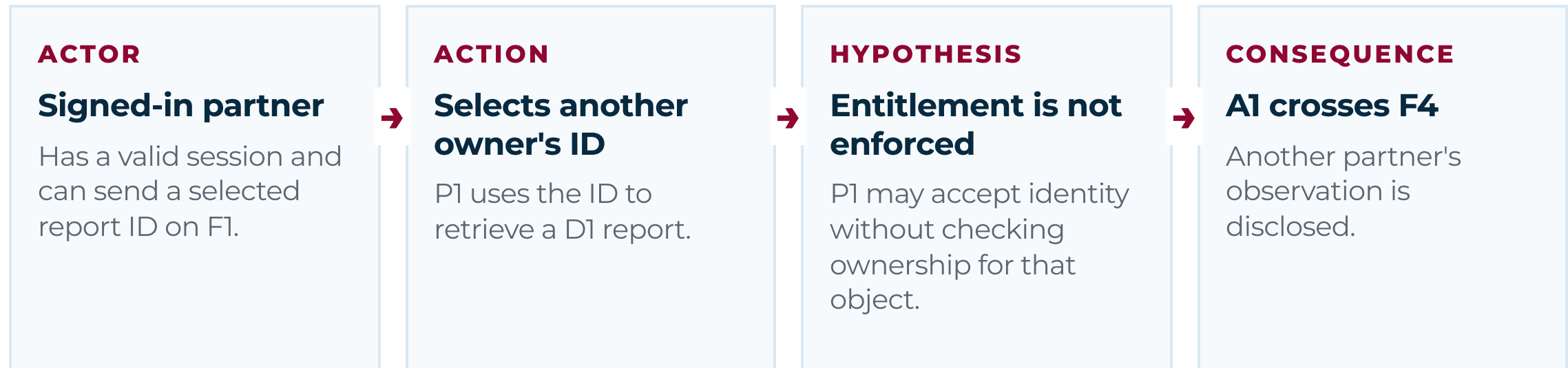
OBSERVATION • E6

A signed-in caller selects report 101 and receives it on the normal path.

QUESTION • Q1

Where and how is E2 enforced on every report-returning path?

Follow the report key through the authorization decision



The model and normal path support reachability. The failed entitlement decision remains a hypothesis under Q1.

Three taxonomies describe different parts of the same scenario

STRIDE

Information disclosure

The principal consequence is an unauthorized read.

OWASP

A01:2025

The broad concern is access outside intended permissions.

CWE

CWE-639, conditional

The proposed mechanism is a caller-controlled record key.

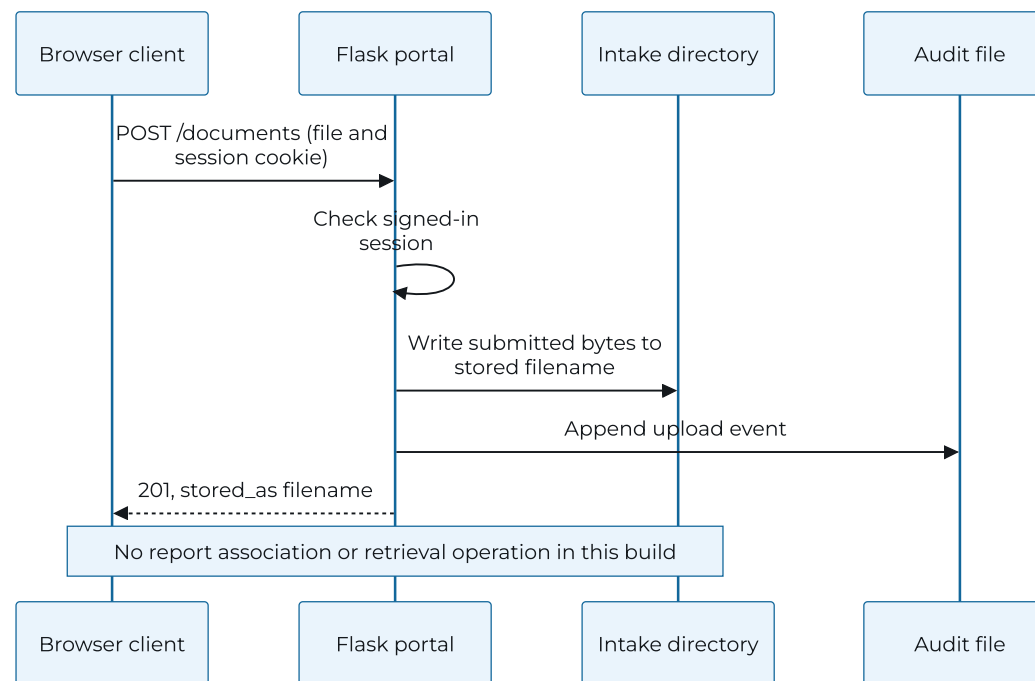
EVIDENCE STATUS

Q1 unresolved

Allowed and denied requests or route evidence could refute the hypothesis.

Changing the request is not automatically tampering with stored data. Choose the primary category from the consequence you actually described.

Document intake creates storage and audit questions

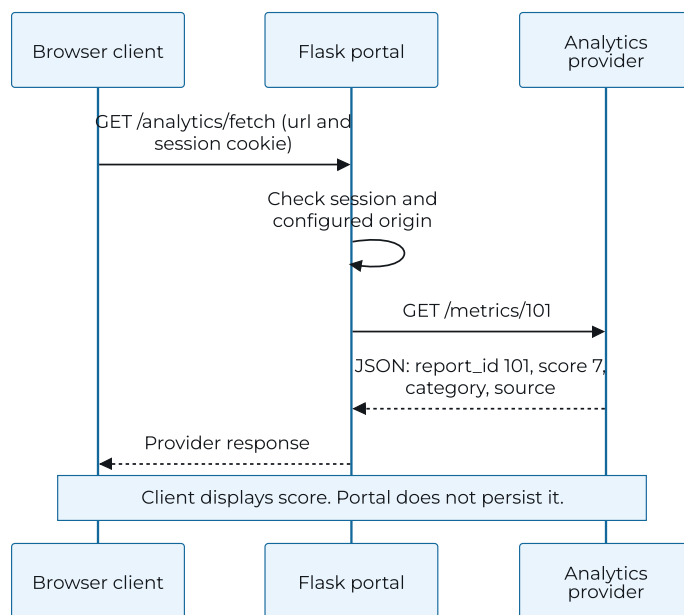


Ask: can filename choice or repeated submission replace stored bytes, misstate the receipt, or weaken the audit trail? The supplied build does not attach this file to a report.

ADDITIONAL WORKFLOW VIEWS • ANALYTICS

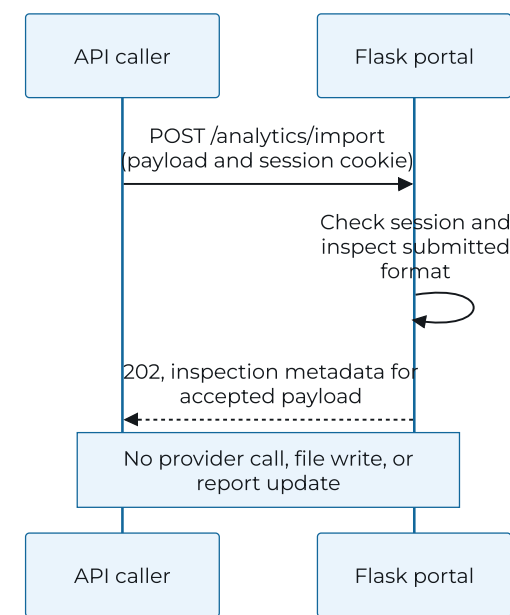
Fetch and import expose different trust questions

ANALYTICS FETCH



Ask: how are provider destination, report identity, timeout, and failure constrained?

ANALYTICS IMPORT



Ask: what is decoded, inspected, executed, persisted, or rejected?

Do not merge the scenarios: fetch crosses to a provider; import performs local format inspection and makes no provider call or file write.

PASTA • APPLIED, NOT MEMORIZED

PASTA organizes the same FRX evidence into seven stages

Stage	FRX work product	Example
1–2 • Objectives + scope	Decision, business workflow, boundaries	Protect partner observations while enabling assigned review
3 • Decompose	Context, component, data, sequence, DFD views	Browser → portal → reports table → JSON
4–5 • Threat + weakness	Scenario register and evidence questions	Partner selects report 102; entitlement enforcement unresolved
6–7 • Attack + risk	Feasibility, consequence, response, proof	Test permit/deny behavior and brief remaining uncertainty

PASTA is a process frame. STRIDE is a discovery prompt. Neither replaces evidence or the model.

METHOD CHOICE

Use the method that matches the work product

STRIDE IS PRIMARY HERE

Systematically question modeled elements and flows, then write distinct causal scenarios.

Output: the Lab 2 scenario register.

PASTA SUPPLIES CONTEXT

Connect objectives, decomposition, attack reasoning, and later risk analysis across a broader engagement.

Limit: this workshop is not a complete PASTA execution.

Unit 1
model



Unit 2
scenarios



Unit 3
risk and response



Unit 4
review

Steps 1–3: select, question, and broaden

1 • SELECT A PATH

Choose a component or boundary-crossing flow other than T1. Record its model IDs and evidence.

2 • APPLY STRIDE

Ask all six questions about requests, returns, stores, dependencies, and effects. Retain reasons.

3 • BROADEN

Use the supplied Top 10 reference to find a plausible mechanism the first pass may have missed.

Starting point: Lab 1 DFD, flow key, assets, E1–E6, and Q IDs

Steps 4–7: write, refine, consolidate, and cover

4 • WRITE

Assign T2 onward.
Record actor,
precondition,
action/path, failure,
asset, and consequence.

5 • REFINE

Explain a precise CWE
mapping or name the
evidence needed to
choose one.

6 • CONSOLIDATE

Merge duplicate
cause/effect records;
aim for distinct surfaces,
not equal categories.

7 • COVER

Mark each surface
covered, considered
with reason, or still
requiring investigation.

2A: first new causal record after Step 4. 2B: linked register and coverage review after Step 7.

Build a scenario register another analyst can challenge

OPEN

Lab 2 student guide, your Lab 1 model, FRX evidence packet, threat reference, and record structures.

DO

Complete Steps 1–7. Retain T1; develop T2 onward across additional review surfaces.

PRODUCE

Linked causal scenarios, mapping rationales, evidence gaps, and a coverage record—without risk ratings or mitigations.

Check 2A after Step 4 • Check 2B after Step 7

LAB 2 DEBRIEF

Can a peer trace and potentially disprove each scenario?

TRACE

Point from T ID to model IDs, actor, preconditions, action, hypothesized failure, asset, and consequence.

Name the evidence already supporting the path.

CHALLENGE

Explain the STRIDE, OWASP, and CWE relationships.

Name the observation that could refute the failure or change the mapping.

Coverage means every modeled surface was considered and dispositions are visible—not that every box has six findings.

From threat scenario to defensible response

Turn uncertainty into a decision, required behavior, and proof.

FRX T1 • FOUR SEPARATE JUDGMENTS

Do not rate the CWE label—rate the complete FRX scenario

Likelihood

Can a signed-in partner select report 102, and what entitlement control actually mediates that path?

Impact

What harm follows if watershed observations, ownership, and attribution reach the wrong partner?

Risk result

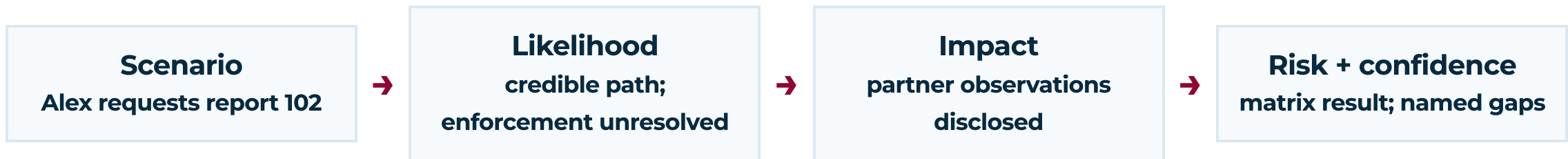
Which cell follows when the supported likelihood and impact arguments enter the approved matrix?

Confidence

How much rests on unresolved route behavior, operating scale, recovery, or owner criteria?

RISK ARGUMENT • SAY “BECAUSE”

A rating must preserve the evidence behind it



USEFUL

“Likelihood is Medium because report selection is reachable, but the entitlement branch is not yet verified.”

NOT USEFUL

“Likelihood is High because broken access control is serious.”

“Not shown” does not mean “not implemented”

SUPPORTED NOW

- The browser can request report 101 by ID.
- The schema records owner and assignment.
- A normal success returns report fields.

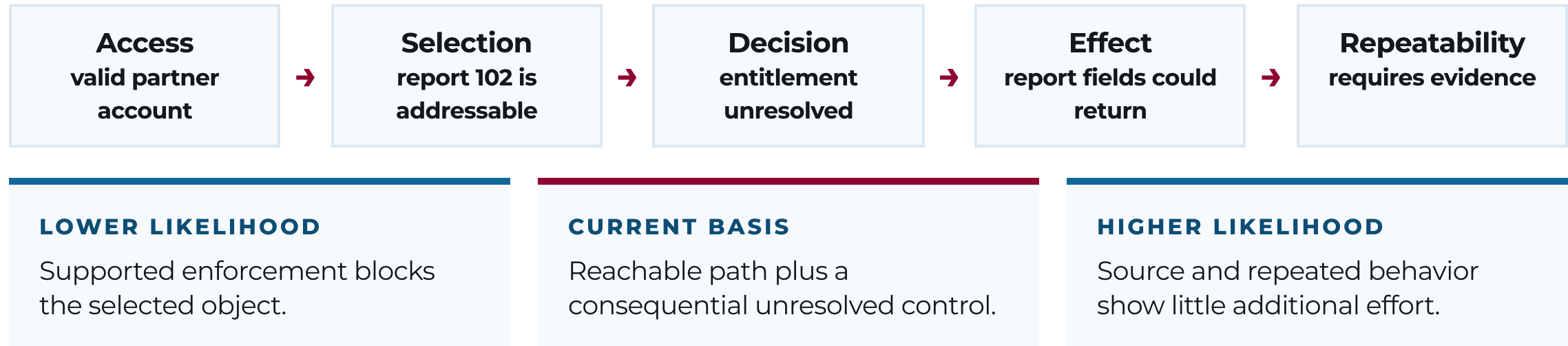
STILL UNRESOLVED ON DAY 1

- Which branch authorizes report 102?
- What denial response omits protected fields?
- Does the same rule cover search and analytics?

Record the unknown, its evidence owner, and the fact that would change the rating. Do not convert missing evidence into a failed control.

LIKELIHOOD · COMPLETE PATH

Rate the FRX event from access to protected effect



IMPACT • CONCRETE FRX CONSEQUENCES

Name what the organization must protect or recover

CONFIDENTIALITY

Another partner receives watershed observations, classification, ownership, and attribution.

INTEGRITY

Overwritten intake bytes or altered report meaning undermines later analysis and provenance.

AVAILABILITY

Portal, SQLite, intake storage, or provider failure delays required research review.

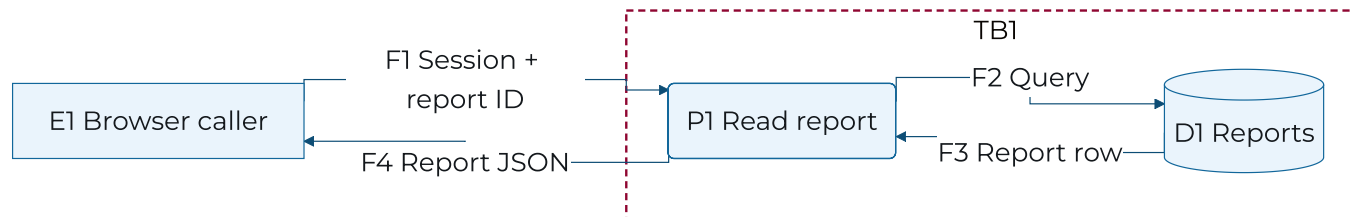
Impact asks what happens if the event occurs. Likelihood, vulnerability labels, and local classroom containment do not lower the consequence.

The matrix combines judgments; it does not create them

Likelihood ↓ / Impact →	Low	Medium	High
Low	Low	Low	Medium
Medium	Low	Medium	High
High	Medium	High	High

FRX T1 example: Medium likelihood + High impact → High risk result, with limited confidence until report-entitlement behavior is verified.

The DFD shows which facts the rating must consider



READ THE PATH

F1: access and object selection

P1/TB1: enforcement evidence

D1: ownership and protected fields

F4: disclosure effect

The diagram organizes the facts. The rating still requires context, consequence criteria, evidence, and uncertainty.

Each response changes a different part of the report path

MITIGATE

Enforce subject-to-report entitlement before any protected fields return.

AVOID

Temporarily disable report-detail access while enforcement remains unresolved.

SHARE / TRANSFER

Assign implementation, policy, monitoring, and response duties by agreement; retain remaining obligations.

ACCEPT

An authorized owner knowingly retains the bounded risk with rationale and review triggers.

“Investigate” may improve confidence, but it does not by itself reduce exposure or complete a risk response.

Preserve legitimate report access while blocking the wrong object

Option	Effect on FRX	What must be proved
Enforce entitlement	Alex can read report 101; Alex cannot read report 102; Riley can read assigned report 101.	Permit, deny, role, and response-field behavior
Hide links only	Changes the browser display but leaves caller-supplied IDs able to reach the route.	Does not satisfy trusted-service enforcement
Randomize IDs	Makes guessing harder but does not decide whether a known object is authorized.	Does not satisfy subject-action-object binding

Recommended response: enforce authorization at the trusted portal on every path that releases report data.

REQUIREMENT ANATOMY

Specify observable behavior before naming an implementation



“Use middleware” is a design choice. “Release only claims permitted to the authenticated employee” is required behavior that multiple designs can satisfy.

Require the trusted service to bind subject, action, and object

RG1 • PROPOSED REQUIRED BEHAVIOR

On every claim-detail request, P2 shall release A1 only when the authenticated employee is currently entitled to the selected claim. A denied request shall return no protected claim fields.

SCOPE

Every claim-detail path, not only displayed links.

OWNER

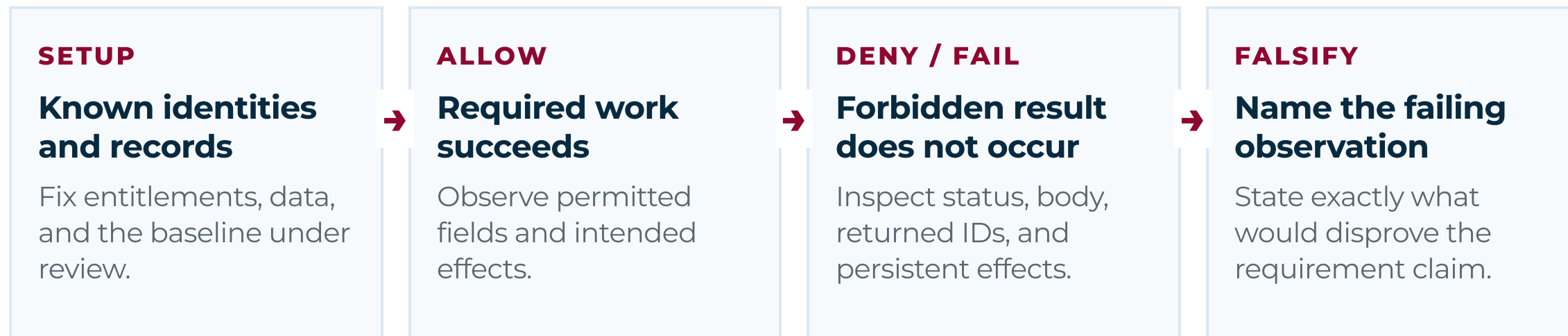
Engineering implements and supplies evidence; the policy owner defines entitlement.

BASIS

Data-specific authorization at a trusted service layer.

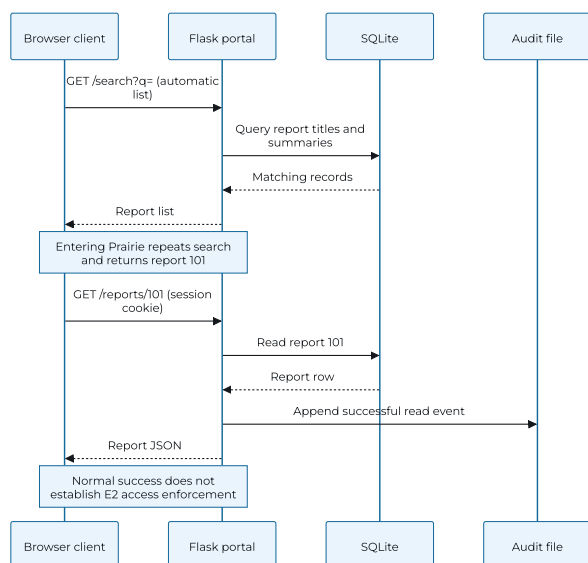
VERIFICATION ANATOMY

Proof needs a legitimate success and a meaningful failure



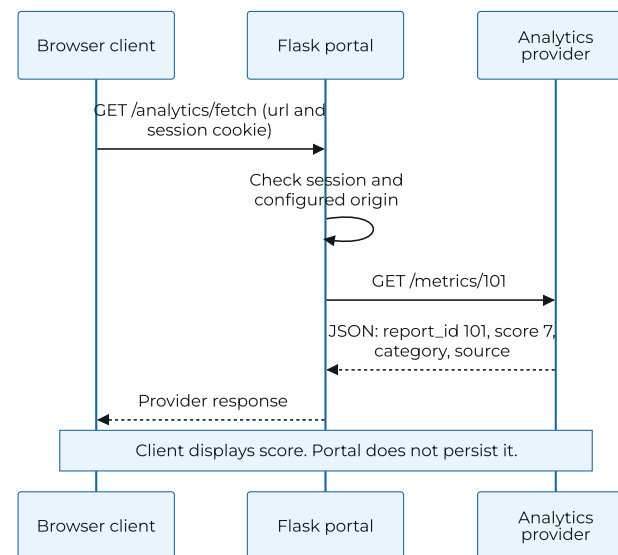
Denial-only testing can “pass” by breaking the entire feature. Verification must preserve the allowed workflow.

Fixing one route is incomplete when other paths release report data



Search + detail: authorize list membership and selected-object release.

Analytics: bind the requested report and returned score to permitted report context.



R1: On every report read, search result, and report-related analytics request, the portal releases data only when the authenticated subject is entitled to the selected report.

Verify both entitlement and preservation of legitimate work

Case	Supplied identity and request	Required observation
Allowed	Alex → 101; Jordan → 102/103; Riley → assigned 101/103; administrator → all.	Correct permitted report fields return on the intended path.
Denied object	Alex → 102; Riley → unassigned 102.	No protected report fields or unauthorized record returns.
No session	Unauthenticated report-returning request.	No protected report data returns.
Path parity	Direct read, search, and report-related analytics.	The same current entitlement governs every returned report field.

Inspect status, body fields, returned report IDs, and side effects. These are proposed observations—not evidence the baseline already passes.

T1 • WHAT REMAINS

Preserve residual risk, uncertainty, and decision ownership

RESIDUAL RISK

Compromised legitimate accounts, excessive administrator authority, and any prior copies.

OUTSTANDING EVIDENCE

Q1 route and allowed/denied behavior across direct, search, and analytics paths.

OWNERS AND NEXT ACTION

Engineering supplies evidence; coordinator confirms policy; service owner decides any interim restriction.

Revisit the Medium-likelihood judgment when Q1 is answered. Do not call R1 implemented or V1 passed before that evidence exists.

DREAD · HISTORICAL CONTEXT AND LIMITATION

DREAD can prompt discussion; it cannot replace the risk argument

DAMAGE

What harm follows?

REPRODUCIBILITY

Can the event repeat?

EXPLOITABILITY

What access and effort?

AFFECTED USERS

How broad is exposure?

DISCOVERABILITY

How visible is the condition?

USEFUL FRX PROMPT

Which evidence would distinguish one authorized report read from repeatable cross-partner disclosure?

MISLEADING SHORTCUT

Averaging five disputed numbers into a precise-looking score without preserving assumptions or consequence criteria.

LAB 3 PROCEDURE • JUDGE AND PRIORITIZE

Steps 1–3: select, rate, and compare

1 • SELECT RECORDS

Retain T1 and choose two learner-authored scenarios with more than one mechanism. Record why they merit detailed treatment.

2 • RATE WITH EVIDENCE

State likelihood and impact separately, apply the matrix, record confidence, and name facts that could change each judgment.

3 • COMPARE PRIORITIES

Explain the order, ties, and whether urgent evidence collection changes what should happen first.

Checkpoint 3A after Step 2: one learner-authored rating with evidence, assumptions, matrix cell, and change fact

Steps 4–7: respond, require, verify, and retain

4 • RESPOND

Compare at least two plausible options for one learner-authored scenario. Record tradeoff, owner, and escalation.

5 • REQUIRE

Assign R2 onward. State actor/resource, trigger, required and forbidden behavior, failure handling, basis, and owner.

6 • VERIFY

Assign V2 onward. Define setup, action, allowed, denied/failure, falsifier, and links to T/R.

7 • RETAIN

Record residual risk, missing evidence, owner, next action, and what will reopen the judgment.

Checkpoint 3B: another analyst can follow $T \rightarrow R \rightarrow V$, see how proof could fail, and identify the responsible owner.

Build response records an engineer can implement and a reviewer can test

OPEN

Lab 3 student guide, existing scenario register, FRX evidence packet, risk reference/matrix, and record structures.

DO

Complete Steps 1–7. Retain T1; develop two learner-authored scenarios through rating, response, R/V, and residual risk.

PRODUCE

Linked risk/response records with evidence, assumptions, alternatives, owners, allowed/denied proof, and next action.

Check 3A after Step 2 • Check 3B after Step 7

LAB 3 DEBRIEF

Can an engineer act—and can a reviewer prove failure?

DEFEND THE DECISION

Explain likelihood, impact, matrix, confidence, priority, response choice, alternative, authority, and tradeoff.

CHALLENGE THE CHAIN

Point from T to R to V; name the allowed workflow, denied/failure observation, falsifier, owner, residual risk, and next action.

Different ratings and responses can be defensible. Unsupported certainty, broken traceability, and untestable behavior are not.

Review the reasoning; preserve the evidence

Peer challenge turns a Day 1 model into a focused implementation-review handoff.

Review the FRX reasoning—not the drawing style

PEER CAN ESTABLISH

The report-read path is traceable from caller through TB1, P1, D1, and F4.

T1, R1, V1, evidence questions, and uncertainty agree with that path.

PEER CANNOT ESTABLISH

The vulnerable route actually enforces entitlement.

A checklist rule passes, remediation works, risk is accepted, or FRX is approved.

Peer disposition, implementation evidence, and authorized system disposition are three separate decisions.

PEER REVIEW • FIRST PASS

If the artifact needs narration, it is not ready to hand off

REVIEWER OPENS

- scope and baseline
- context, component, data, sequence, and DFD views
- asset, threat, response, verification, and question records

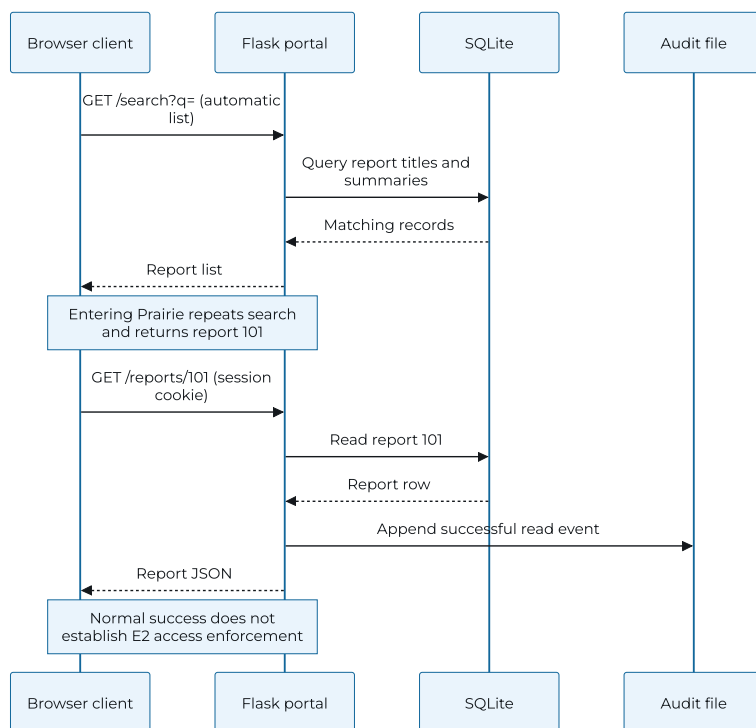
REVIEWER TRACES

- **partner.alex** → report 102
- F1 → P1 → D1 → F4
- T1 → risk argument → R1 → V1

The author explains only after the reviewer records what was clear, unsupported, contradictory, or missing.

PEER TEST 1 • TRACE THE PATH

The sequence view lets a peer challenge each handoff



CHECK AT EACH MESSAGE

Direction: who sends what?

Identity: which subject is trusted?

Decision: what branch should occur?

Effect: which row, event, or response results?

Evidence: what supports the claim?

Coverage means every FRX surface has a reasoned disposition

Surface	Acceptable disposition	Example
Report read / search	Linked scenario or distinct evidence question	Object authorization versus query interpretation
Document intake	Scenario, justified exclusion, or open inquiry	Repeated filename and byte preservation
Analytics fetch / import	Separate mechanisms when decisions differ	Destination constraint versus received-data format
Audit / error behavior	Evidence-linked scenario or explicit deferral	Attribution, secret exposure, and failure detail

A scenario count does not prove coverage. A duplicate phrasing does not create a distinct mechanism.

PEER TEST 3 • CHALLENGE ASSUMPTIONS

Preserve supported disagreement as an evidence request

AUTHOR CLAIM

“Partner sessions probably contain an office value that limits report access.”

PEER CHALLENGE

“The supplied session evidence names user ID, username, and role. Show the office attribute and enforcement point—or record them as unresolved.”

Do not average the two positions. Record the disputed premise, the evidence owner, and what result would change the model or risk argument.

PEER TEST 4 • RESPONSE ADEQUACY

Hiding report links does not authorize caller-supplied IDs

APPEARANCE-ONLY CHANGE

Remove report 102 from Alex's browser list.

The caller can still send `GET /reports/102`.

MECHANISM-CHANGING RESPONSE

The Flask route binds session subject, read action, and selected report before returning protected fields.

Use the model to locate the trusted decision. A response that never reaches that point cannot satisfy R1.

FRX authorization proof needs permit and deny cases

PERMIT

Alex reads owned report 101 and receives the expected protected fields.

DENY

Alex requests Jordan's report 102 and receives no protected fields.

ROLE PATH

Riley reads assigned report 101; an unassigned report is denied.

A service that denies every request passes the negative case and still violates required work. A useful proof distinguishes correct authorization from total outage.

FEEDBACK QUALITY

“Improve security” hides the reviewer’s reasoning

WEAK

Comment: Fix authorization.

The author must guess the record, evidence, affected path, consequence, and completion condition.

ACTIONABLE

Comment: V7 tests denial only. R4 also requires permitted report access. Add an allowed case and identify the result that would falsify both behaviors.

Specificity is not length. It is traceable location, evidence, decision effect, and an observable request.

The drafted verification proves only denial

R1 • REQUIRED BEHAVIOR

Release report fields only when the signed-in partner owns the selected report or the analyst is assigned; denied requests return no protected fields.

V1 • DELIVERED DRAFT

As Alex, request Jordan's report 102. Confirm that the request is denied and no protected report fields return.

What implementation defect could still make this test pass?

A portal that blocks every report would pass V1

REQUIREMENT CLAIM

Alex receives report 101; Alex receives no protected fields from report 102.

OBSERVED GAP

The draft exercises only the second behavior.

DECISION EFFECT

The reviewer cannot tell whether mitigation preserves the ordinary report-read workflow.

The problem is not “too few tests.” The problem is that a required behavior has no observation capable of failing.

Write the evidence, consequence, and requested finish line

PR1 • FRX REVIEW RECORD • V1

Evidence: R1 requires both entitled release and protected denial; V1 exercises only denial.

Issue and consequence: the test can pass if the portal blocks every report, so legitimate report access is not verified.

Requested action: add an allowed owner case with expected report fields and name any failure of allowed or denied behavior as a falsifier.

Revise the artifact and preserve why it changed

DISPOSITION

Revise. PR1 identifies a required behavior not exercised by V1.

Preserve the original draft and link it to the revised verification.

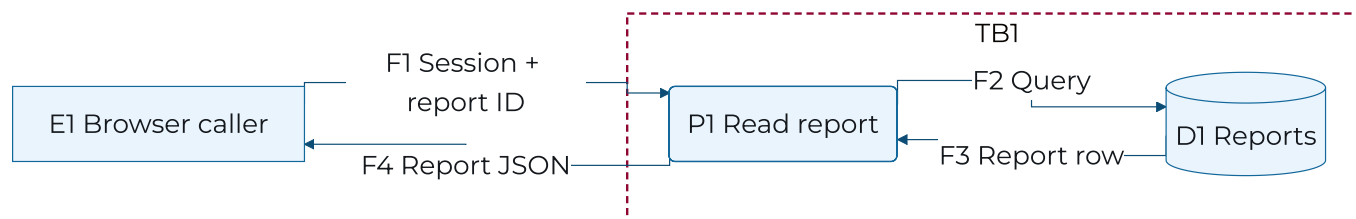
V1 • REVISED VERIFICATION

Alex receives report 101 fields; report 102 returns no protected fields; a request without a session returns no protected report data.

Falsifier: any request returns protected report data outside current entitlement—or Alex cannot complete the permitted report 101 read.

FRX PEER-REVIEW EXAMPLE • INCOMPLETE RESPONSE

The proposed fix never reaches the modeled trust decision

**PEER ARTIFACT SAYS**

Response: hide other partners' report links.

Verification: confirm those links disappear.

Missing: evidence at P1 before F4 releases report JSON.

The diagram makes the defect visible: the proposed response changes the browser, not the trusted portal decision.

Link display and service authorization answer different questions

E2 • POLICY INTENT

Partners read their own reports; assigned analysts and administrators have defined access.

E6 • OBSERVED WORKFLOW

A signed-in caller selects report 101 and receives its details.

F1 / F4 • MODELED PATH

The browser sends a session and report ID; the portal returns report details.

Q1 • UNRESOLVED

Where and how does every report-returning path enforce E2?

Hiding a link changes discovery in the client. It does not establish the portal's decision for a directly submitted valid ID.

Make the comment specific enough to implement and re-review

PR1 • T1 RESPONSE AND V1

Evidence: F1 carries the signed-in caller's report ID to the portal, and Q1 leaves E2 enforcement unresolved.

Issue and consequence: link hiding does not govern a direct report request, so the hypothesized cross-partner disclosure path remains.

Requested action: require entitlement at the trusted service for every report-returning path and define allowed, denied-object, and no-session observations.

STEP 6 • RECONCILE THE COMMENT

Every material comment receives a reasoned disposition

REVISE

The artifact misses the supported issue. Change the linked record and identify the new revision.

RETAIN WITH REASON

The required behavior already exists. Point to the exact field and explain why no change is needed.

ESCALATE

A policy, evidence, tolerance, or authority decision is missing. Name the owner and request.

“Disagree” and silence are not dispositions. Preserve the comment and the reasoning that resolves it.

EXTEND THE REVIEW BEYOND PR1

Use evidence questions—do not manufacture defects

MODEL ACCURACY

Does the intake sequence support every drawn connection or persistent association?

VERIFICATION CRITERIA

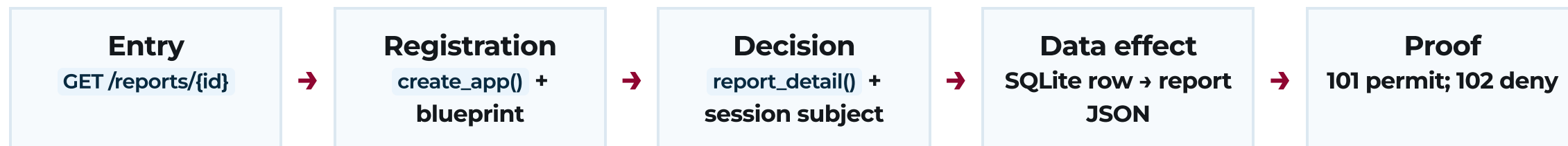
Does a phrase such as “works under load” name a measurable observation and evidence owner?

BOUNDARY RATIONALE

Does each drawn boundary represent a supported change in trust or authority rather than visual grouping?

A supported confirmation is valid. A material correction must follow from the artifact and supplied evidence.

Hand Day 2 a path, decision, and proof question



SOURCE STARTING POINTS

app.py , states/vulnerable.py , database.py , and the browser client.

QUESTION TO ANSWER

Where does the reviewed implementation bind authenticated subject, read action, and selected report—and what happens on denial?

Steps 5–7: comment, disposition, and implementation target

5 • COMMENT

Assign PR IDs; record location, evidence, issue or confirmation, consequence, and requested action.

6 • RECONCILE

Revise, retain with reason, or escalate each material comment; preserve revisions and unresolved owners.

7 • HAND OFF

Name scope, significant risks, selected Day 2 paths, requirements, evidence, limits, and decision owners.

Checkpoint 4B: every material comment has a disposition and the handoff names concrete implementation evidence.

Review, reconcile, and prepare the Day 2 evidence path

OPEN

Lab 4 student guide, exchanged Lab 1–3 artifact, FRX evidence packet, and record structures.

DO

Complete Steps 1–7. Read independently, return comments, then reconcile with the author.

PRODUCE

PR records, revised or confirmed work, dispositions, and a specific Day 2 handoff.

Check 4A after Step 4 • Check 4B after Step 7

Can another analyst follow the comment, decision, and correction?

REVIEWER DEFENDS

Target and location, evidence, material consequence, requested action, and the limit of the review.

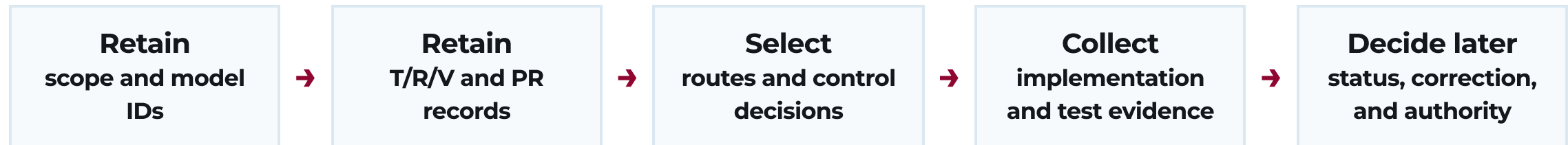
AUTHOR DEFENDS

Revise, retain with reason, or escalate; changed record or precise pointer; remaining uncertainty and next action.

Different outcomes can be defensible. Unsupported certainty, broken traceability, ignored comments, and untestable behavior are not.

DAY 1 → DAY 2

Carry questions forward without upgrading them into findings



The reconciled model tells Day 2 where to look and what would count as proof. It does not predetermine what the code review will find.



THREAT MODELING AND SECURE CODE REVIEW

Day 2 • Secure Code Review Practicum

Follow one FRX review from threat-informed planning through a challenge-ready delegate recommendation.

Six formal labs carry one evidence chain to a decision brief

1 • PLAN Threat-informed scope Lab 1 • CRP1 + selected paths	2 • STRATEGIZE Code Crawl handoff Guided practice • revision 0.3	3 • READ Python security surface Guided practice • revision 0.4	4 • OBSERVE Manual baseline crawl Lab 2 • EV + CF records
5 • GOVERN Risk + criteria Lab 3 • RS status	6 • VALIDATE Signals + supply chain Lab 4 • SV + FN records	7 • VERIFY Remediation proof Lab 5 • RM records	8 • BRIEF Delegate decision Lab 6 • DB1 + revision 0.9

Retain stable identifiers and record history. Evidence, rule status, signals, findings, remediation proof, risk, recommendation, and the authorized decision remain distinct.



DAY 2 • UNIT 1

Convert the threat model into a review plan

Choose what to inspect, why it matters, and what would count as proof.

CONTINUOUS EVIDENCE CHAIN

Follow one FRX report-read question from model to decision



Concrete question: may partner Alex retrieve report 102, which belongs to another partner?

Record rule: later evidence may change the conclusion; it never rewrites what was observed.

Keep stable identifiers. Revise with evidence, rationale, version, and owner instead of silently rewriting history.

THE WORK PRODUCT

CRP1 turns T1 into an executable report-read review

WHY THIS PATH?

- **T1:** report data may cross an entitlement boundary
- **R1:** authorize the subject against the selected report
- **Q1:** who should read owned vs assigned reports?
- **Baseline:** supplied vulnerable FRX state

HOW WILL WE TEST IT?

- **PTH1:** `GET /reports/<report_id>`
- Alex reads owned report 101 and other-owner report 102
- compare no-session and missing-report branches
- inspect returned fields, audit effect, and policy owner evidence

CRP = Code Review Plan. PTH = one selected implementation path inside that plan.

MOVE 1 • CHOOSE THE REVIEW TYPE

Match the strategy to the decision and available evidence

BASELINE

Establish evidence across the current application or a bounded subsystem.

Use when: no trusted current review exists.

CHANGE

Evaluate a defined revision and the behavior it can affect.

Use when: trusted baseline evidence exists.

HYBRID

Review a change plus nearby paths where the baseline is weak or risk is high.

Use when: both conditions apply.

FRX choice: bounded baseline review. Day 1 supplies a reviewed model, but no trusted implementation-review baseline exists.

MOVES 2 AND 3 • RETAIN AND INVENTORY

Carry Q1 into the FRX files that could answer it

CARRY FROM DAY 1

A1: report title, summary, owner, assignment, and classification fields.

T1/R1/V1/Q1: entitlement threat, required subject-object check, verification branches, and unresolved policy owner.

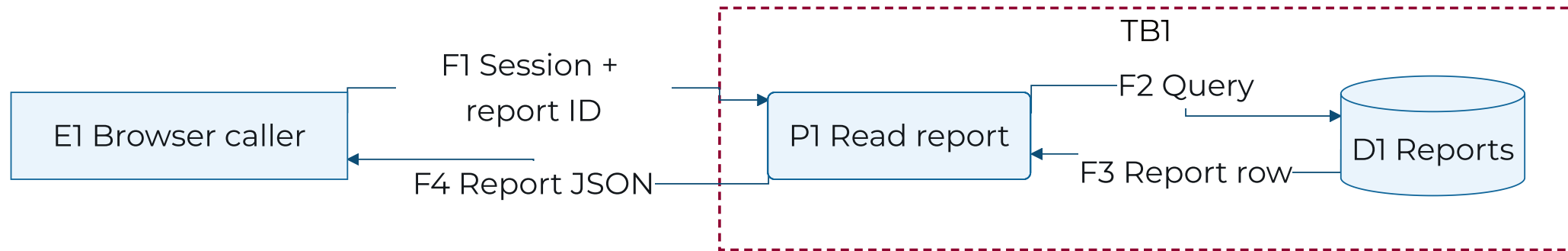
LOCATE IN IMPLEMENTATION

`app.py:create_app` selects a state module; `states/vulnerable.py:report_detail` handles the route; SQLite stores `owner_id` and `assigned_analyst_id`.

`client.js`, audit output, and characterization tests expose effects and expectations.

MOVE 4 • SELECTION TEST

PTH1 connects a selected ID to protected report data



Path: session identity + caller-selected report_id → route → report lookup → entitlement decision → JSON + audit. **Consequence:** report 102 crosses TB1 to the wrong partner if the decision is absent.

MOVE 5 • PROOF DESIGN

Plan the exact FRX branches that can support or refute R1

ORDINARY

Partner Alex + report 101 → expected 200; verify report fields and read-audit entry.

BOUNDARY

Same Alex session + report 102 → expected denial if ownership governs; inspect body and audit effect.

FAILURE

No session + report 101 → 401.
Alex + report 999 → 404. Confirm no protected row is returned.

Record what evidence would support the requirement *and* what evidence would refute it.

MOVE 7 • COVERAGE

A bounded review is honest about what it did not establish

Included

Functionality, routes, identities, stores, dependencies, configurations, tests.

Excluded

Deliberate omissions with consequence, owner, and later evidence path.

Re-plan

Baseline drift, unexpected path, missing evidence, or violated assumption.

Escalate

Authority, policy, severity, access, or dependency question exceeds the team's decision.

CHECKLIST BOUNDARY

Plan access now; assign applicability and status later

UNIT 1 MAY RECORD

- authorized checklist version and access owner
- domains likely relevant to selected paths
- evidence that will be needed
- conflicts or guidance requiring follow-up

UNIT 1 MUST NOT RECORD

- pass or fail based on a title
- not applicable without rationale
- a copied rule as implementation proof
- an application recommendation

Controlled checklist text stays in the authorized review workflow; the learner plan uses stable references and evidence questions.

Start from the reconciled handoff and implemented source surface

CRP1 FRAME

Baseline: supplied vulnerable FRX state

Type: bounded baseline review

Purpose: collect implementation evidence for later governed status and recommendations.

Carry forward: T/R/V/Q, residual-risk, and peer-review IDs.

SOURCE ORIENTATION

Application factory and route registration; request handlers; session identity; SQLite access; upload storage; audit output; configured analytics dependency; thin client; tests.

Limits: navigation points are not proof, and the dependency remains separately evidenced.

PTH1 follows T1/R1/V1/Q1 into report retrieval

SELECTED PATH

Interface: GET /reports/<report_id>

Identity + input: session identity and caller-selected report ID.

Data + effect: report fields return; a read-audit event may be written.

SELECTION BASIS

T1 concerns report data A1 and the unresolved entitlement policy Q1.

R1/V1 require evidence from every path that returns a report—not merely a familiar route.

PTH1 is selected for review. It does not yet pass or fail a requirement or checklist rule.

PTH1 asks where subject, object, and policy meet

SOURCE STARTING POINTS

Report-detail handler; authentication helper; report ownership and assignment fields; client report loader; relevant tests.

Trace query, decision, returned fields, audit, and error behavior.

PROOF NEEDED

Locate the trusted-service entitlement decision. Observe an allowed report, another valid report ID, and no-session behavior.

Inspect returned fields and any audit or failure effects.

Q1 remains open: evidence can reveal implementation behavior; the service owner must confirm intended entitlement policy.

Steps 1–4 produce defensible path choices

1 • ESTABLISH

Decision recipient, purpose, baseline, review type, and authority limit.

2 • RETAIN

Day 1 IDs, evidence, consequence, requirement, proof question, uncertainty.

3 • INVENTORY

Functions, identities, assets, stores, dependencies, source families, tests.

4 • SELECT

Keep PTH1; add two paths with distinct decisions or effects and explicit bases.

Checkpoint D2-1A: another reviewer can explain why each path matters and where inspection begins.

Steps 5–7 define proof, support, and stopping

5 • DEFINE PROOF

Decision, alternate/failure path, support/refute observations, fields, effects, logs.

6 • ALLOCATE

Expertise, references, optional tools, owner, timebox, evidence name, manual responsibility.

7 • RECONCILE

Coverage, exclusions, dependencies, open questions, re-plan and escalation triggers.

Checkpoint D2-1B: a peer can start the review without guessing and knows what the plan cannot decide.

Build CRP1 and extend the selected path set

OPEN

Reconciled Day 1 handoff, FRX evidence packet, source orientation, record structures.

DO

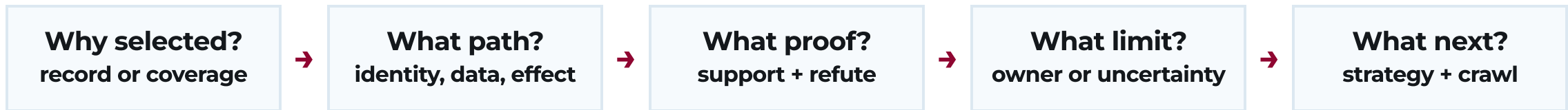
Complete Steps 1–7. Retain PTH1 and add at least two defensible PTH records.

PRODUCE

CRP1 revision 0.2 with proof, owners, timeboxes, exclusions, and stop/escalation rules.

D2-1A after Step 4 • switch roles • D2-1B after Step 7

Defend one path from Day 1 input to planned proof



Unit 2 will test whether the plan's review strategy, Code Crawl navigation, and checklist preparation are fit for the selected paths.



DAY 2 • UNIT 2 • JOINT WARFARE ANALYSIS CENTER (JWAC) CHECKLIST

Review strategy, Code Crawl, and JWAC checklist

Choose review depth, navigate the implementation, and prepare governed evidence.

CARRIED-FORWARD UNIT 1 EVIDENCE

Revise CRP1 with source navigation—without claiming evidence

FIELD RESEARCH EXCHANGE (FRX)

CRP Code Review Plan · **PTH** selected review path

A asset · **T** threat · **R** requirement

V verification · **Q** open question

LATER EVIDENCE

EV evidence note, created only after inspection

Checklist status begins as **Not Reviewed** and changes only through the authorized workflow.

Unit 2 produces CRP1 revision 0.3 and updated PTH navigation—not findings or EV records.

STEP 1 • SELECT REVIEW STRATEGY

The strategy must fit both the baseline and the decision

BASELINE

Build evidence across a current application or bounded subsystem.

Use when: no trusted review baseline exists.

CHANGE

Inspect a defined revision and the behavior it can affect.

Use when: trustworthy baseline evidence exists.

HYBRID

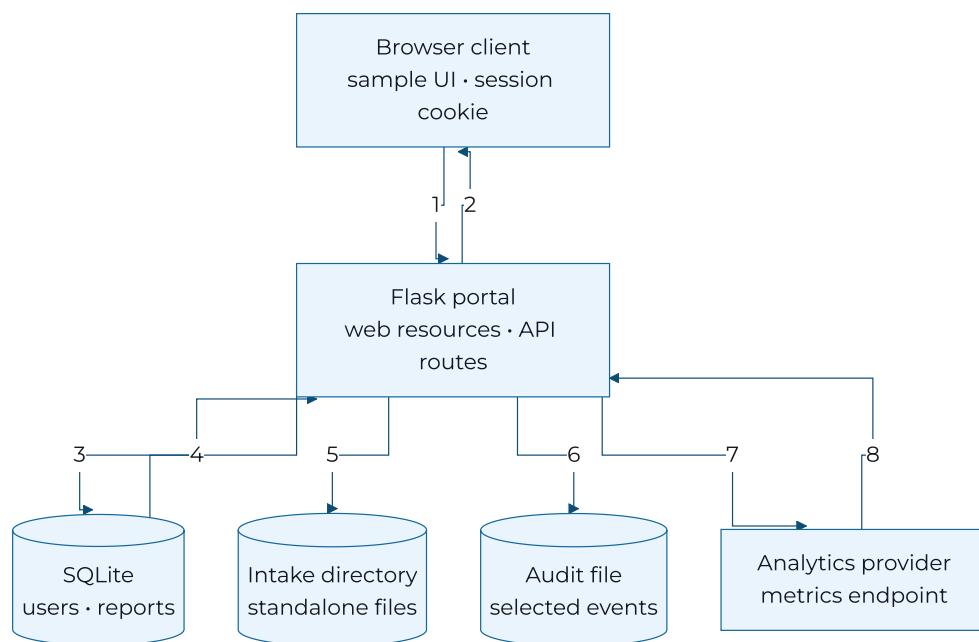
Review a change plus nearby paths whose baseline is weak or materially affected.

Use when: both conditions apply.

FRX: use a bounded baseline strategy for `states/vulnerable.py` ; add adjacent search, session, database, audit, client, and test paths because they can change the report-access conclusion.

STEP 2 • CODE CRAWL ANCHORS

Code Crawl turns the FRX architecture into a source route



PTH1 CRAWL

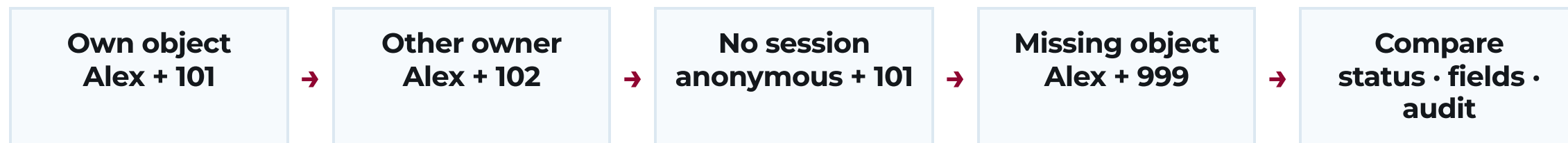
`app.py:create_app()` → selected `states` module → registered blueprint → `report_detail(report_id)`.

Then follow `session["user_id"]`, SQLite `reports`, owner/assignment fields, `_audit()`, `jsonify()`, `client.js:loadReport`, and characterization tests.

Search terms locate these surfaces; registration and calls establish reachability.

STEP 4 • FOLLOW BRANCHES

PTH1 needs four executions—not one successful read

**EXPECTED DISTINCTION**

101 and 102 are both valid rows;
object authority—not existence
—should separate them.

BYPASS QUESTION

Can the API route return 102
even if the browser never offers
that selection?

FAILURE QUESTION

Do 401 and 404 branches return
protected fields or write
misleading audit entries?

STEP 6 • CHECKLIST GOVERNANCE

A checklist rule is a governed evidence question—not proof

1 • IDENTIFY

Authorized version, stable rule ID, owner, and access conditions.

2 • HYPOTHESIZE

Likely relevance to the PTH, with a domain and reason.

3 • SPECIFY

Source, behavior, configuration, dependency, or owner evidence needed.

4 • DEFER STATUS

Keep Not Reviewed until the authorized evidence pass in Unit 5.

Do not mark pass from a title, fail from a suspicion, or not applicable because evidence is inconvenient.

STEP 6 • EVIDENCE STANDARD

Local rule identity and current verification guidance work together

PRESERVE THE GOVERNED RULE

Retain its stable ID, version, intent, owner, required workflow, and original wording in the authorized record.

Do not silently rewrite a local rule.

PLAN CURRENT PROOF

Use the OWASP Application Security Verification Standard (ASVS) 5.0.0 or another current authoritative source to define testable evidence where appropriate.

Record conflict, deviation, or escalation explicitly.

CRP1 keeps a bounded baseline strategy for PTH1

SELECTION BASIS

PTH1 carries T1/R1/V1/Q1 into `GET /reports/<report_id>`.

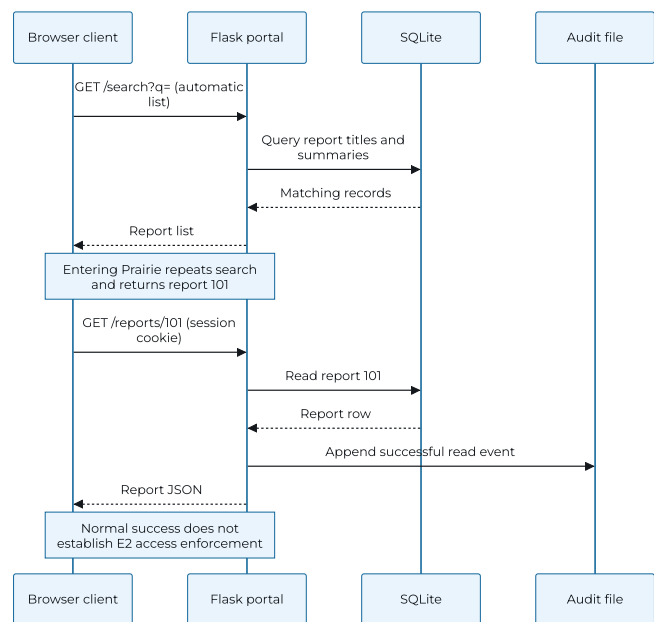
Report data A1, the subject-object decision, and entitlement-policy uncertainty make the path material.

STRATEGY REFINEMENT

Bounded baseline: Day 1 produced a reviewed model, not current implementation evidence.

Include shared session logic, report storage fields, client use, tests, audit behavior, and every report-returning sibling path needed for coverage.

PTH1 crawl follows the implemented report-read sequence



BACKWARD

JSON fields ← **jsonify** ← selected row ← **report_id**.

SIDEWAYS

_authenticated · search · owner fields · audit · tests.

BRANCHES

101 · 102 · no session · 999; compare response and audit.

PTH1 records what later evidence must establish

SOURCE EVIDENCE

Identity origin; report selection; subject-object-policy decision; response projection; audit and error branches.

BEHAVIOR EVIDENCE

Permitted, alternate-object, no-session, and missing-report results; returned fields; audit/error effects.

CHECKLIST PREPARATION

Likely access-control, session, output/data, and logging domains; attach authorized rule IDs and owner later. **Status: Not Reviewed.**

Stop or re-plan if the baseline differs, Q1 policy remains unavailable, or a sibling report path changes the coverage claim.

GUIDED PRACTICE PROCEDURE • FRAME AND CRAWL

Steps 1–3 choose a strategy and expose the path

1 • SELECT

Open CRP1 revision 0.2 and one PTH. Record baseline, change, or hybrid with a reason.

2 • ANCHOR

Name the entry, identity or authority, asset or effect, proof target, and likely source family.

3 • TRACE

Sketch forward, backward, and sideways moves; add alternate, bypass, and failure questions.

D2-2A means Day 2, Unit 2 checkpoint A: a peer can follow the route without guessing why each move matters.

Steps 4–5 make the route usable by the next reviewer

4 • PREPARE EVIDENCE

Name source and behavior evidence, a falsifier or alternate explanation, likely checklist domains, and a stop or re-plan condition.

Keep status **Not Reviewed**.

5 • CHALLENGE AND REVISE

A partner follows the crawl and identifies one unsupported jump, missing branch, or unclear owner.

Revise or retain with reason as CRP1 revision 0.3.

D2-2B means Day 2, Unit 2 checkpoint B: the route is ready for Unit 3 source reading without claiming evidence that has not been gathered.

Refine one PTH for the Python-reading unit

OPEN

Unit 2 learner guide, CRP1 revision 0.2, one selected PTH, and the FRX source orientation.

PRODUCE

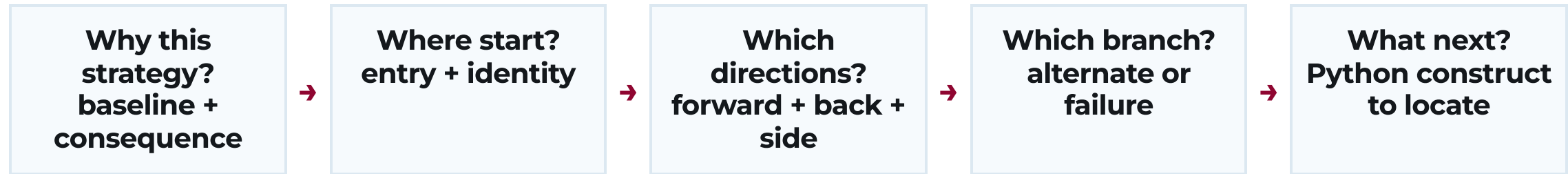
CRP1 revision 0.3 plus one PTH with strategy, crawl directions, branches, evidence plan, and checklist preparation.

CHECK

D2-2A after Step 3 · partner challenge · D2-2B after Step 5.

This is guided practice—not a new formal lab. Preserve PTH IDs and change history.

Defend one crawl from selection to the next source question



Unit 3 begins with CRP1 revision 0.3 and asks how Python and Flask express each promised navigation step.



DAY 2 • UNIT 3 • SECURE CODE REVIEW

Reading the Python security surface

Turn a selected review path into a source trace another reviewer can resume.

CARRIED-FORWARD UNIT 2 EVIDENCE

The Unit 2 handoff tells you why and where to read

FIELD RESEARCH EXCHANGE (FRX)

CRP Code Review Plan · **PTH** selected review path

T threat · **R** requirement · **V** verification · **Q** open question

UNIT 3 OUTPUT

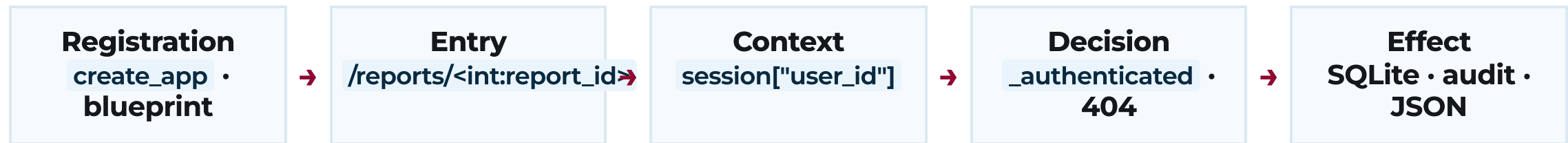
A source-reading trace added to one PTH and CRP1 revision 0.4.

EV evidence notes begin only in Unit 4.

Keep the PTH ID, strategy, anchors, branches, evidence plan, and stop condition visible while reading.

PORTABLE MENTAL MODEL

Read the FRX request as bindings, calls, branches, and effects

**PYTHON SIGNAL**

Indentation defines scope; names bind values; calls transfer control; exceptions redirect it.

FLASK SIGNAL

A decorator binds an HTTP rule to a view; request context supplies inputs and session state; the return becomes a response.

PASS 1 • BIND THE ENTRY

Registration explains how an HTTP request reaches code

APPLICATION ASSEMBLY

Find the application factory, imported module, blueprint registration, middleware, and error handlers.

Question: which implementation is active in this baseline?

ROUTE BINDING

Read the decorator's method, path, and converters; then read the decorated function signature.

Question: what input arrives before the first line executes?

@blueprint.get("/reports/<int:report_id>") converts the selected path segment to an integer before calling report_detail(report_id) .
Reachability still depends on create_app() registering that state module's blueprint.

Flask exposes several input channels with different shapes

URL AND HEADERS

Route variables, `request.args`, headers, cookies, method, and content type.

BODY

`request.form`, `get_json()`, raw bytes, and uploaded files.

AMBIENT CONTEXT

`session`, `current_app`, environment-derived settings, and imported constants.

FRX examples: `report_id` comes from the URL; `q` from `request.args`; credentials and uploads from `request.form/files`; identity from `session`; signing key and analytics URL from configuration.

Authentication and authorization answer different questions

IDENTITY STATE

Where is the current subject established, loaded, refreshed, and cleared?

Look for session keys, tokens, user loaders, decorators, and helper returns.

AUTHORITY DECISION

Where are subject, object, action, role, ownership, assignment, state, and policy evaluated together?

Look beyond a generic “logged in” gate.

FRX contrast: vulnerable `_authenticated()` asks only “is `user_id` present?” **Remediated** `_can_read(user, report)` evaluates `role`, `owner_id`, and `assigned_analyst_id`.

PASS 4 • MAP DECISIONS AND BRANCHES

Control flow reveals which outcomes are actually reachable

CONTINUE

Assignments and calls move values or authority toward another decision or effect.

DIVERT

if, early **return**, exception handling, and helper results create alternate outcomes.

STOP

Status responses, raised errors, or failed lookups end the path—or transfer it to a handler.

FRX vulnerable route: 401 if no session; 404 if no row; otherwise audit and return the row. Missing branch: no 403 decision compares the current user with the selected report.

Exact calls tell you what kind of boundary is crossed

PERSISTENCE

`connection.execute(...).fetchone()`
loads the row; upload `save()`
writes submitted bytes.

INTERPRETATION

`jsonify(report=dict(report))`
crosses the HTTP boundary;
`pickletools` inspects analytics
bytes without executing them.

EXTERNAL EFFECT

`urlopen` contacts analytics;
`_audit()` appends selected
events; shared handlers may
expose error details.

Capture the fully qualified call, arguments, return type, limits, and failure behavior—not just a familiar keyword.

The route rarely contains the whole security decision

CONFIGURATION

Factory defaults, environment values, limits, cookie settings, state selection, and paths.

DEPENDENCIES

Imported package, fully qualified function, declared version, wrapper behavior, and external service contract.

PROOF SURFACES

Tests, fixtures, error handlers, logging helpers, sibling routes, callers, and response consumers.

PTH1 sideways scope: factory state selection, `_authenticated()` , report owner/assignment fields, search sibling route, `client.js:loadReport` , audit helper, error handler, and characterization tests.

PTH1 reaches a route through the selected state module

REGISTRATION

`app.py:create_app` imports `states.{state}`, calls its configuration hook, and registers its blueprint.

Question: which state is the reviewed baseline?

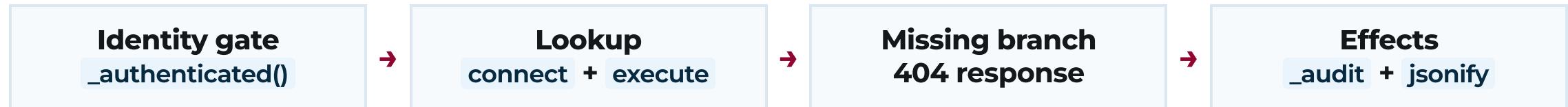
ENTRY AND INPUT

`@blueprint.get("/reports/<int:report_id>")` binds PTH1 to `report_detail(report_id)`.

Input: converted report ID plus request-session context.

This locates reachable code. It does not establish what every branch permits.

PTH1 exposes a session gate, lookup, branches, and effects



KNOWN FROM READING

The helper tests session presence; the route loads one row, handles a missing row, writes an audit entry, and returns report fields.

STILL UNRESOLVED

Where does subject-object policy use current identity with report ownership, assignment, or role across every report-returning path?

The source handoff links PTH1 to its supporting files

LOCATOR	WHY IT MATTERS	NEXT QUESTION
<code>database.py</code>	Reports carry owner and analyst-assignment fields	Where are those fields consumed in a release decision?
<code>client.js:loadReport</code>	Selected ID enters the route; returned fields reach the page	Which response fields become visible effects?
<code>app.py</code> handlers	Errors may change response content	Which route failures transfer to a shared handler?
<code>frx-project/tests</code>	Tests may state or omit expected branches	Are permitted, denied-object, and no-session outcomes covered?

PTH1 now has a source-reading trace. Unit 4 still must create the EV records and candidate-finding evidence.

GUIDED PRACTICE PROCEDURE • BIND AND TRACE

Steps 1–3 establish entry, input, identity, and decisions

1 • BIND

Open CRP1 revision 0.3, one PTH, and the FRX source orientation. Find registration, route, and callable.

2 • MARK

Record request and ambient inputs, expected types, transformations, identity, and authority sources.

3 • BRANCH

Trace helpers, conditions, early returns, and error transfers for ordinary and alternate paths.

D2-3A: a partner can enter at the same callable and reconstruct the identity and branch map.

Steps 4–6 make the source trace useful in Unit 4

4 • FOLLOW

Name exact query, file, serialization, outbound, crypto, response, log, or exception calls and their effects.

5 • CHASE

Follow only supporting configuration, dependencies, helpers, tests, callers, and handlers that can change the PTH.

6 • HAND OFF

Partner-resume the trace; record the next locator and proof question; revise CRP1 to 0.4.

D2-3B: the trace is ready for Unit 4 without an EV record, finding, or checklist-status change.

Trace one selected PTH through the FRX source

OPEN

Unit 3 learner guide, CRP1 revision 0.3, one selected PTH, and the FRX source orientation.

PRODUCE

One seven-pass source trace plus CRP1 revision 0.4 and a precise next proof question.

CHECK

D2-3A after branch mapping · partner resume · D2-3B after the Unit 4 handoff.

This is guided practice—not a new formal lab. Preserve PTH IDs and do not create EV or finding records.

Defend one source trace from registration to proof question

Where bound?
factory + route



What enters?
input + identity



What decides?
helpers +
branches



What happens?
operation + effect



What next?
locator + proof

Unit 4 begins with CRP1 revision 0.4 and turns the retained source trace into line-level and runtime evidence.



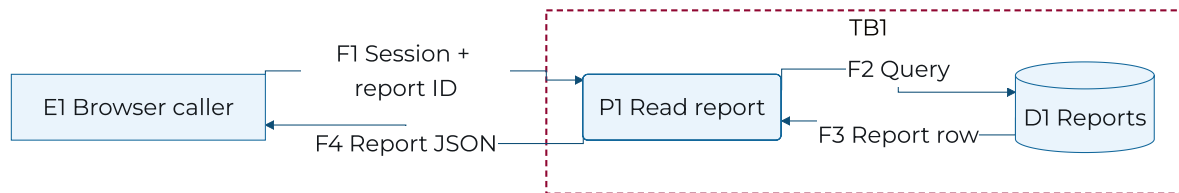
DAY 2 • UNIT 4 • SECURE CODE REVIEW

Practicum 3: manual baseline crawl

Turn a selected source trace into evidence another reviewer can reproduce.

CARRIED-FORWARD UNIT 3 EVIDENCE

Lab 2 begins at the FRX report boundary—not a blank repository

**STARTING RECORD**

PTH1: Alex requests report 101, 102, or 999 through `GET /reports/<report_id>`.

Question: where does current identity meet report owner/assignment policy before fields cross TB1?

New records: EV = direct observation; CF = bounded difference supported by EV.

Start with CRP1 revision 0.4, the exact baseline, source locator, expected branches, proof question, and policy uncertainty.

EVIDENCE DISCIPLINE

Observation, interpretation, and disposition are different records



PRESERVE

Baseline, identity, input/object, branch, effect, alternate explanation, and reviewer.

DEFER

Checklist status to Unit 5; signal reconciliation to Unit 6; remediation proof to Unit 7; recommendation to Unit 8.

EVIDENCE SET

Pair the HTTP result with the decisions and effects around it

EVIDENCE	RECORD	WHY IT MATTERS
Source	File, function, line, input, condition, exact call	Shows the implemented decision and operation
Runtime	Identity, object/input, status, body, repeat	Shows one reachable execution outcome
Effect	Returned record, stored bytes/hash, outbound result	Shows what crossed or changed a boundary
Log / failure	Audit entry, exception, handler response	Shows alternate behavior and secondary exposure
Peer	Independent rerun or retained discrepancy	Tests record reproducibility

PTH1 source evidence separates session presence from report authority

```
def _authenticated():  
    if "user_id" not in session:  
        return jsonify(error="Login required"), 401  
def report_detail(report_id):  
    if response := _authenticated():  
        return response  
    report = connection.execute(...).fetchone()  
    ...  
    return jsonify(report=dict(report))
```

EV1 • DIRECT OBSERVATION

The active route checks session presence, loads the selected report ID, handles missing, audits, and returns the row.

No ownership, assignment, role, or other subject-object decision is called in this function.

One identity and four objects make the conclusion reproducible

No session
report 101 → 401



Partner Alex
own 101 → 200



Partner Alex
other-owner 102 → 200



Partner Alex
missing 999 → 404

EV2 • EFFECTS

Responses for 101 and 102 include their report/owner fields; audit output records both reads.

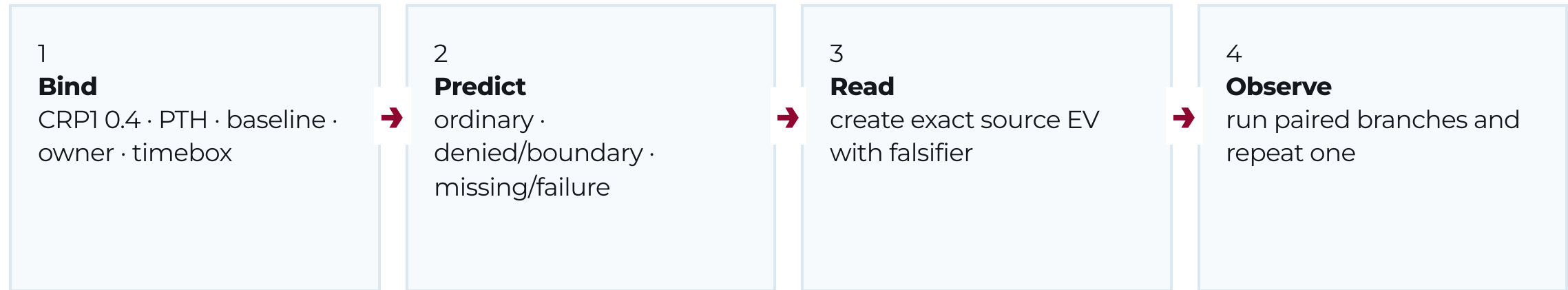
CF1 • CANDIDATE

The tested baseline permits an authenticated partner to retrieve another partner's report by selecting its ID.

Link EV1/EV2 to T1/R1/V1/Q1 and PTH1. Defer checklist status, CWE, risk, remediation, and recommendation.

LAB 2 PROCEDURE • ESTABLISH THE CHAIN

Steps 1–4 connect the retained question to direct evidence



D2-4A: a peer can point from identity/input through decision and operation to the observed response or side effect.

LAB 2 PROCEDURE • FINISH AND HAND OFF

Steps 5–7 test effects, judgment, and reproducibility

5 • FOLLOW EFFECTS

Separate response, state, external effect, audit/log, exception, and handler evidence. Add one focused EV from a second PTH.

6 • RECONCILE

Record a candidate finding, matched behavior, or evidence gap. Preserve conflict and uncertainty.

7 • REPRODUCE

A peer reopens the source and reruns one observation. Revise CRP1 to 0.5.

D2-4B: primary PTH + at least two EVs • focused second-PTH EV • peer result • zero or more justified CFs • checklist Not Reviewed.

Build evidence another reviewer can reproduce

OPEN

Lab 2 student guide · CRP1
revision 0.4 · selected PTHs ·
source orientation

PRODUCE

Primary source/runtime EV
chain · focused second-path EV ·
bounded disposition · CRP1
revision 0.5

CHECK

D2-4A at the evidence chain ·
D2-4B after peer reproduction
and handoff

Use only the supplied synthetic scenarios. The observation runner is evidence input—not a verdict.

Defend the evidence chain and name its boundary



Unit 5 begins with CRP1 revision 0.5, EV/CF records, and Not Reviewed checklist rules—then applies governed criteria and status.



DAY 2 • UNIT 5 • SECURE CODE REVIEW

Review by risk and governed criteria

Let applicability and evidence decide each checklist status.

CARRIED-FORWARD UNIT 4 EVIDENCE

RS1 governs one concrete FRX access-control decision

EVIDENCE BROUGHT FORWARD

EV1: route checks session presence, then loads and returns the selected row.

EV2: Alex receives owned report 101 and other-owner report 102.

CF1: selected-ID access crosses the ownership boundary.

DECISION CREATED HERE

RS1: JWC-CRC-000013 / CRC-AAS-000605.

Record applicability, local question, direct evidence, status, comments, limits, and owner.

Do not merge RS1 with CF1 or the final recommendation.

Start with CRP1 revision 0.5 and retain every PTH/T/R/V/Q/EV/CF link that supports or limits the rule decision.

RISK-INFORMED COVERAGE

Severity orders attention; evidence decides status

Choose work where Day 1 consequence, local severity, reachable paths, and uncertainty make missed evidence costly.

High does not mean Open. Low does not mean safe. Unreviewed does not mean failed.

FIVE GOVERNED DOMAINS

Build / input · validation, configuration, failure, operations

Access / session · identity, cookies, protected resources

Cryptography · secrets, transport, primitives, password storage

Logging / auditing · errors, event coverage, sensitive data

Process / supply chain · review, SBOM, licenses, tools, deviations

AUTHORIZED STATUS VOCABULARY

Four statuses answer four different evidence conditions

Open

Applicable; sufficient evidence shows the required condition is not met.

Not A Finding

Applicable; sufficient evidence shows the condition is met for the reviewed scope.

Not Applicable

Positive scope evidence shows the condition does not apply; rationale and owner retained.

Not Reviewed

Not evaluated, or the required evidence has not yet been examined.

A gap stays Not Reviewed unless direct evidence independently establishes Open or Not A Finding.

EVIDENCE SUFFICIENCY

Status changes only when the evidence answers the rule's question

QUESTION	WHAT THE RECORD NEEDS	IF MISSING
Where?	Benchmark, rule, baseline, feature, path, configuration, or process	Cannot bound applicability
What condition?	Local test question plus current clarification and conflict note	Title matching replaces evaluation
What happened?	Direct EV facts, identity/input/object, control, response/effect, reproduction	Open or Not A Finding is unsupported
What limits it?	Unexamined paths, missing policy/tool/deployment evidence, falsifier, owner	Scope is overstated

Not Applicable needs positive feature/scope evidence. “I did not find it” is usually Not Reviewed.

CONFLICT AND DEVIATION

Preserve the local rule—and make the mismatch reviewable

EXAMPLE • JWC-CRC-000002

The local special-character check spans multiple interpreters.

For the FRX database path, current guidance asks whether SQL code and data remain separate through parameterization—not whether every special character is rejected.

CONFLICT RECORD

Preserve: rule ID/version and authorized wording

Clarify: ASVS v5.0.0-1.2.4 and the observed SQL sink

Record: aligned/broader/narrower/conflict, proposed interpretation, approving owner, and deviation/escalation

Do not silently modernize the rule, obey a stale implementation example, or use current guidance to erase local authority.

RS1 binds the authorization rule to one protected report path

GOVERNED IDENTITY

Benchmark: JWAC Code Review Checklist VIR1 · Release 1 · 15 April 2026

Rule: JWC-CRC-000013 / CRC-AAS-000605 · High

Domain: access / session

QUESTION AND CRITERION

Applicable: authenticated report-detail path returns a protected report object

Question: is the required subject-object decision enforced before release?

Current: ASVS v5.0.0-8.2.2 · aligned

The rule's High severity moves it forward in the review queue. It does not choose the status.

EV1, EV2, and CF1 support Open for the reviewed path



PRECISE MAPPING

CWE-639 fits the user-controlled-key authorization mechanism.

A01:2025 is broad context only.

LIMITS AND OWNERS

Scope: vulnerable baseline and report-detail path. Q1 entitlement policy or another trusted layer remains a falsifier.

Engineering owns response; coordinator owns policy confirmation.

LAB 3 PROCEDURE • ESTABLISH THE RULE DECISION

Steps 1–3 bind scope, applicability, and current criteria

1**Freeze + cover**

CRP1 0.5 · benchmark · baseline · five domains · choose two rules

**2****Apply?**

feature · scope · evidence · owner;
never convenience-based N/A

**3****Translate + reconcile**

local question · current criterion ·
alignment/conflict

Starting work: use the supplied RS1; complete two additional RS records across at least two other domains.

Steps 4–6 make the status reviewable

4**Prove + status**

direct EV · sufficiency/gap · status ·
details/comments

**5****Map + govern**

precise CWE · context ·
conflict/deviation · owner · Unit 6
signal

**6****Challenge + retain**

peer disposition · CRP1 0.6 · exact Unit
6 handoff

D2-5A: rule → question → evidence → status. **D2-5B:** three RS records +
five-domain view + peer challenge + Unit 6 signal list.

Assign status another reviewer can defend

OPEN

Lab 3 guide · CRP1 revision 0.5 ·
Lab 2 EV/CF records · current-
criteria reference · authorized
checklist

PRODUCE

Supplied RS1 · two additional RS
records · five-domain coverage ·
CRP1 revision 0.6

CHECK

D2-5A after evidence/status · D2-
5B after peer challenge and Unit
6 handoff

**Use governed evidence—not rule-title matching, category matching,
or an unexamined tool result.**

Defend the status—and name what could change it

Which rule?
benchmark • ID •
version • severity



Why applicable?
feature • scope •
owner



What proof?
criterion • EV/CF •
reproduction



What status?
details •
comments •
mapping



What remains?
conflict • deviation
• signal • authority

Unit 6 begins with CRP1 revision 0.6 and exact manual, automated, secret, dependency, SBOM, license, threshold, and owner signals to validate—not with trusted tool verdicts.



DAY 2 • UNIT 6 • SECURE CODE REVIEW

Validate manual, automated, and supply-chain signals

Turn pipeline assertions into reproducible reviewer dispositions.

DECISION BOUNDARY

FRX-PIPE-006 says what ran—not whether its claims are true



A successful job proves that one configured job completed. It does not prove coverage, absence, exploitability, checklist closure, or release approval.

SECRET-DETECTION SIGNALS

The FRX match becomes meaningful only when its use is traced

```
def configure_app(app, _settings):  
    app.config.update(  
        SECRET_KEY=  
        "training-only-hard-coded-..."  
    )
```

Locator: `states/vulnerable.py`, configuration path. Value intentionally redacted.

TWO PROOF QUESTIONS

What is it? A fixed training string assigned to Flask's session-signing configuration—not merely a high-entropy-looking literal.

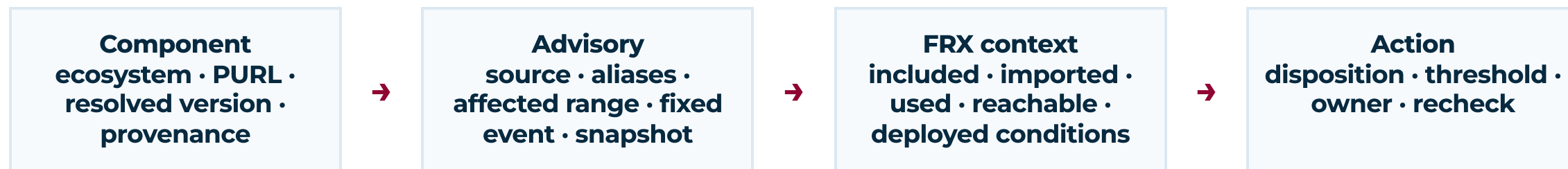
What can it affect? Session-cookie integrity; the vulnerable error path also returns the configured value.

Record safely: signal IDs and a redacted locator, never the matched value.

Never paste the matched value into an SV record. Preserve the signal ID, redacted locator, evidence, owner, and response state.

DEPENDENCY AND ADVISORY SIGNALS

Package identity is necessary; advisory applicability is a second decision



The frozen bundle matches Flask 3.1.2 to GHSA-68rp-wp8r-4726. Review must still test its cache, response-policy, and session-access conditions.

A valid SBOM can still be incomplete—and a license ID is not approval

INVENTORY PROOF

Compare manifest and resolved lock to SBOM components, PURLs, dependency edges, lifecycle scope, timestamp, generator, and composition.

FRX fixture: 3 components; composition explicitly incomplete.

LICENSE PROOF

Validate SPDX identifier or expression and evidence source. Then ask which organizational policy, use/distribution facts, owner, and exception record govern approval.

Tool action level $\neq$ legal or release approval.

SV1 binds two alerts to one configured signing key

BATCH AND ASSERTION

FRX-PIPE-006 · vulnerable baseline · source/artifact hashes verified

SAST-001 + SECRET-001 · same file and line · High

Tool claim: hard-coded credential/secret; SAST proposes CWE-798.

DIRECT CONTEXT

A fixed string is assigned to Flask **SECRET_KEY** in **configure_app**.

Flask uses the value to sign session cookies. The bound error path also returns the configured value.

Contrary evidence: none in the vulnerable state changes or rotates it.

Two alerts become one confirmed mechanism—not two findings



RECORD EFFECT

Link the relevant EV/RS chain; preserve both tool IDs; update comments/status only through checklist authority.

HARD BOUNDARY

No production exposure, final risk, corrected state, regression proof, residual-risk acceptance, or release recommendation is decided.

LAB 4 PROCEDURE • BIND AND REPRODUCE

Steps 1–3 produce the first defensible learner disposition

- 1 Bind batch**
CRP1 0.6 · hashes · producer · scope ·
exclusions · thresholds
- **2 Queue claims**
six families · exact assertion · locator ·
duplicate · proof need
- **3 Reproduce**
source/use · contrary evidence ·
disposition · owner · D2-6A

Starting work: retain SV1/FN1; choose one other manual/SAST/secret claim and one dependency/SBOM/license claim.

Steps 4–6 keep signal truth separate from later decisions

4**Supply chain**

PURL · version · SBOM · advisory · conditions · license owner

**5****Reconcile**

duplicates · manual silence · FN/RS effect · threshold/deviation

**6****Challenge**

peer reproduce · CRP1 0.7 · Unit 7 mechanisms · D2-6B

D2-6A: one reproducible SV. D2-6B: three total SV records + six-family view + governed Unit 7 handoff.

Validate the claim another reviewer can reproduce

OPEN

Lab 4 guide · CRP1 revision 0.6 · existing EV/CF/RS · frozen bundle · authorized checklist channel

PRODUCE

Batch header · supplied SV1/FN1 · two learner SV records · six-family coverage · CRP1 revision 0.7

CHECK

D2-6A after first disposition · D2-6B after peer challenge and exact Unit 7 handoff

A severity, CVSS score, action label, passing gate, or silent scanner may order work. None replaces reproduction.

Defend the disposition—and preserve the next proof burden

What ran?
baseline • profile •
scope • integrity



What claimed?
signal • location •
component •
threshold



What proved?
use • condition •
contrary evidence



What changed?
disposition •
duplicate • FN/RS •
owner



What remains?
Unit 7 correction
and proof • process
gap

Unit 7 begins with confirmed bounded FN mechanisms and exact proof needs—not raw alerts, assumed license approval, or a pipeline pass.



DAY 2 • UNIT 7 • SECURE CODE REVIEW

Practicum 5: remediation and proof

Decide whether a correction changes the mechanism—and whether required work still holds.

FOUR-LANE PROOF MATRIX

RM1 tests the signing-key correction through four concrete lanes

Allowed / ordinary

Valid login creates a session; the same training runtime continues to validate its cookie.

Denied / boundary

No-session request for report 101 returns 401 before protected fields are released.

Failure / error

Error response does not disclose the active signing key or internal private path.

Regression

Fresh runtime gets a different key; cookie flags and ordinary login still work.

For every lane: arrange the precondition, act on the path, observe the response/effect, explain the security meaning, and state the evidence limit.

CHANGE REACH BEFORE TEST EXECUTION

Trace PCH-001 from configuration to every security-relevant effect

CHANGED PATH

`configure_app()` now receives or creates the key → Flask signs the session cookie → later protected requests verify that cookie.

The error handler must also stop returning `current_app.secret_key`.

ADJACENT OBLIGATIONS

Same-runtime restart continuity; clean-runtime key separation; cookie flags; ordinary login; no-session denial; no key disclosure.

Deployment provenance, access, rotation, and backup remain separate owner evidence.

A small diff can change a shared control; a large diff can leave the root cause untouched. Line count measures neither.

FOCUSED TESTS AS REVIEW EVIDENCE

Read the FRX characterization test as evidence with limits

FIXTURE AND BRANCH

`test_state_characterization.py`

creates vulnerable and remediated clients, logs in partner Alex, and requests reports 101 and 102.

OBSERVED CONTRAST

Vulnerable baseline returns 200 for other-owner report 102; remediated baseline returns 403 while owned report 101 remains 200.

LIMIT

This proves two seeded objects in the local fixture. It does not prove production policy, every role, every report-returning path, or deployed configuration.

Green proves the assertions passed—not that the assertions were sufficient, the build was correct, or the application is ready.

RM1 binds FN1 to PCH-001 and tests the signing-key mechanism

FINDING AND CORRECTION CLAIM

FN1 / SV1: one fixed Flask session-signing key in the vulnerable source.

PCH-001: supplied runtime value or generated training-runtime file; Secure, HttpOnly, SameSite=Lax cookie flags.

REACH AND PROOF MATRIX

Configuration → signing key → session cookie → restart continuity → protected request.

Prove fixed assignment absent, key not returned, same-runtime continuity, clean-runtime separation, ordinary login, cookie flags, and no-session denial.

The source hard-code is corrected; production key governance is still unproved

DIRECT PROOF

Fixed assignment absent. Runtime key created without disclosure. Same runtime persists; clean runtime differs. Login succeeds; cookie flags present; no-session report read returns 401.

RM1 DISPOSITION

Verified for the bounded hard-coded-key mechanism in the remediated training state.

Link proof to FN1. An RS change still follows checklist authority.

Remaining evidence: production source/access, permissions/backup, rotation/revocation, previous-session transition, and deployed configuration. Unit 8 must preserve—not silently accept—these gaps.

LAB 5 PROCEDURE • BIND, REVIEW, AND DESIGN

Steps 1–3 establish what the proof must decide

1 • BIND

CRP1 0.7 • integrity • confirmed FN •
PCH • baselines • hashes • owner

2 • REVIEW REACH

root cause • change flow •
callers/helpers • adjacent paths • new
assumptions

3 • DESIGN PROOF

allowed • denied • failure • regression •
source fact • falsifier • D2-7A

Starting work: retain RM1; choose one confirmed FN/PCH pair from the governed D2-6B handoff. Do not promote a raw or deferred signal.

Steps 4–6 produce the Unit 8 evidence set —not its recommendation

4 • EXECUTE

focused scenario • expected/observed •
effect/audit • repeat • mock/fixture limit

5 • RECONCILE

root cause changed? • required work? •
RM status • FN/RS effect • remaining
risk

6 • CHALLENGE

peer recheck • revise/retain/escalate •
CRP1 0.8 • Unit 8 evidence • D2-7B

**D2-7A: bound four-lane plan. D2-7B: RM1 + learner RM + governed
record effects + remaining-risk owners + exact verified, failed, and
missing proof.**

Verify the correction another reviewer can reproduce

OPEN

Lab 5 guide · CRP1 revision 0.7 · confirmed FN handoff · bounded change catalog

PRODUCE

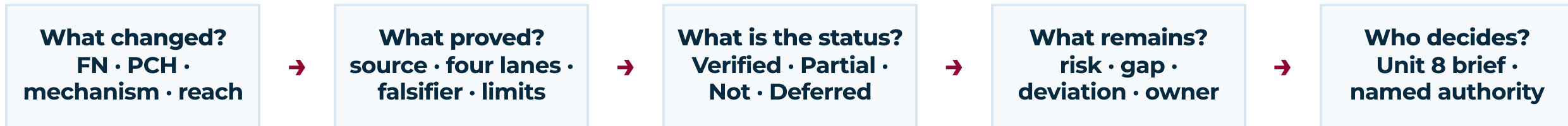
Supplied RM1 · one learner RM · four proof lanes · remaining risk · CRP1 revision 0.8

CHECK

D2-7A before execution · D2-7B after peer challenge and exact Unit 8 evidence handoff

A changed source line, passing status, or green check may support the record. None replaces root-cause and regression proof.

Defend the proof—and preserve the decision still to be made



Unit 8 begins with verified corrections, uncorrected mechanisms, governed status, failed/missing proof, remaining risk, assumptions, and owners—not a preselected recommendation.



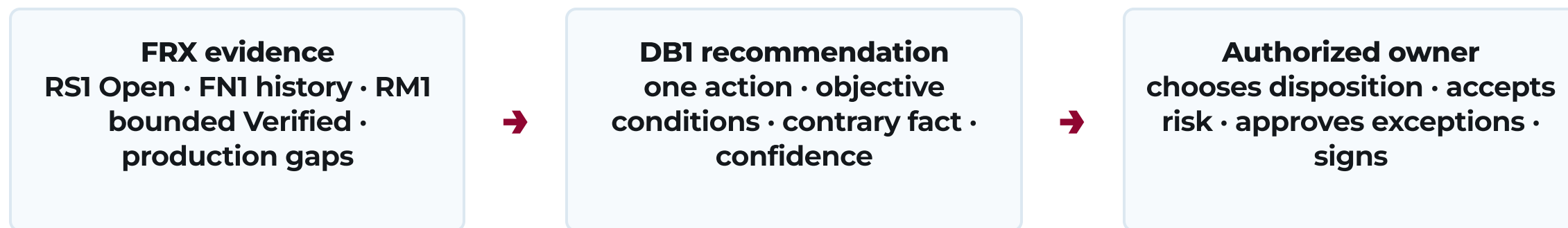
DAY 2 • UNIT 8 • SECURE CODE REVIEW

Delegate decision brief

Turn the review record into a bounded recommendation a named decision owner can act on.

RECOMMENDATION AND AUTHORITY

DB1 turns FRX evidence into advice for a named owner



Assessment of Potential Problems and Risks of Vulnerability Exploitation (APPROVE) supplies a reporting structure. It does not prove who holds authority for this review.

TWO VOCABULARIES • ONE EXPLICIT RATIONALE

Complete example: map one review action to the customer field

EXPENSE LOOKUP EVIDENCE

An employee can retrieve another employee's claim by changing `claim_id`. Source and paired runtime evidence reproduce the release; no correction was supplied.

Review action: Correct. Require object-authorization enforcement and proof for owned, other-owner, no-session, and missing-claim branches.

CUSTOMER-FIELD MAPPING

Recommendation: Disapprove with conditions.

Condition: named engineering owner corrects the release decision; independent reviewer verifies the four branches before reconsideration.

Authority: reviewer recommends; authorized owner selects and signs.

Why the mapping is explicit: Correct describes the review action. Disapprove with conditions is the recommended APPROVE field. They are related, not interchangeable.

RM1 changes one risk input; it does not decide the application

WHAT THE EVIDENCE SUPPORTS

RM1 is **Verified** for the bounded hard-coded signing-key mechanism in the remediated training state. Retain FN1 history and the exact local proof scope.

WHAT THE DECISION STILL NEEDS

Production key provenance, access, permissions/backup, rotation/revocation, prior-session transition, deployed configuration, and authorized owner remain unproved.

Condition candidate: the production secret/deployment owner supplies lifecycle and deployed-configuration evidence; a named reviewer verifies it before this line supports a production recommendation. Overall action and APPROVE value remain unassigned.

LAB 6 PROCEDURE • FRAME, RECONCILE, AND ASSESS

Steps 1–3 establish what the recipient can rely on

1 • BIND

DB1 • decision • recipient • authority
• baseline • scope • timeframe

2 • RECONCILE

record IDs • current status
verified • open • failed
deferred • missing • rejected
locators

3 • UPDATE RISK

event • condition • mitigation •
likelihood • impact • risk •
confidence • D2-8A

**Start with CRP1 revision 0.8 and the D2-7B evidence set. Preserve RM1;
do not convert missing evidence or a rejected signal into a finding.**

Steps 4–6 produce the recommendation—not an unauthorized decision

4 • RECOMMEND

one course action • strongest support/contrary fact • separate template field

5 • WRITE

executive summary • objective conditions • non-compliance • releasability/FGI

6 • BRIEF AND CHALLENGE

90 seconds • peer locator • alternate view • revise/retain/escalate • CRP1 0.9 • D2-8B

Leave signature, risk acceptance, deviation/POA&M approval, and actual organizational disposition unassigned unless an authorized owner responded.

Give the decision owner a recommendation they can challenge

OPEN

Lab 6 guide · CRP1
revision 0.8 · D2-7B
evidence · DB
template · supplied
APPROVE template

PRODUCE

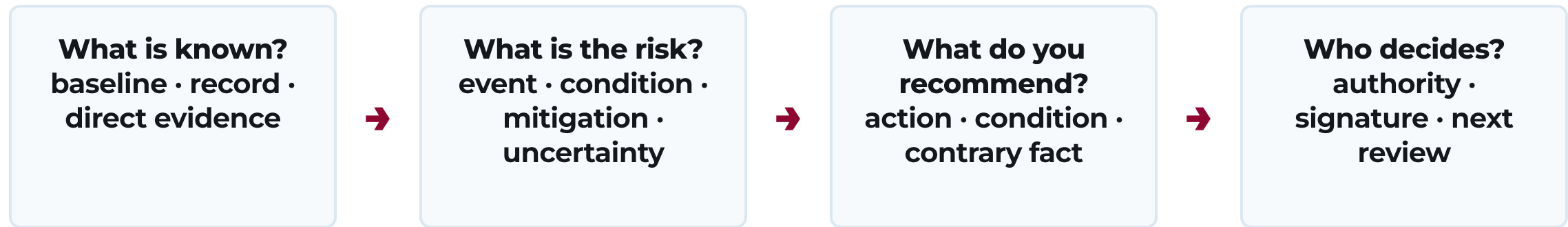
DB1 · risk lines · written
recommendation ·
conditions · 90-second
oral brief · CRP1
revision 0.9

CHECK

D2-8A after risk
synthesis · D2-8B after
peer challenge and
oral delivery

The recommendation must name what is known, what could change it, what should happen next, and who may decide.

Defend the recommendation—and preserve the decision owner's work



A strong DBI lets an authorized owner agree, disagree, request evidence, or impose conditions without losing the review's scope, uncertainty, or decision history.